كورس تأسيسي عملي للمبتدئين والخريجين

كيف تبدأ في GRC

الحوكمة والمخاطر والامتثال من الصفر: تفهم العمل، وتطبّقه على شركة واحدة، ثم تجهز ملفك للوظيفة الأولى.

9 وحدات | حالة عملية واحدة | 4 تطبيقات موجهة | كراسة تمارين وإجابات

G الحوكمة
من يقرر، وبأي قواعد

R المخاطر
ما الذي قد يحدث، وماذا نفعل

C الامتثال
هل نلتزم، وكيف نثبت

ماذا ستستطيع أن تفعل بعد هذا الكورس؟

بعد الكورس ستستطيع أن:

1. تفهم طبيعة العمل في GRC وأدواره اليومية.
2. تميّز بين الحوكمة والمخاطر والامتثال، وتفهم الأساس التقني لما تقيّمه.
3. تنفّذ مهام تأسيسية صغيرة: مسؤوليات، وخطر، وتقييم ضابط، وملاحظة.
4. تختار شهادتك ومسارك التعليمي حسب هدفك ومرحلتك.
5. تجهز ملف أعمال وسيرة ولينكدإن، وتستعد للمقابلة.

ما لا يقدمه الكورس

- ⚠ تأهيلاً كاملاً لإدارة برنامج GRC.
- ⚠ تطبيق ECC كاملاً في جهة حقيقية.
- ⚠ بديلاً عن الخبرة أو الشهادات المهنية.

هو بداية منظمة وصحيحة، تبني عليها.

كيف يسير كل موضوع في الكورس

1

شرح مبسط

الفكرة بلغة واضحة.

← **2**

مثال محلول

نطبقها أمامك على رُفاد.

← **3**

تمرين قصير

تحاول بنفسك في الكراسة.

← **4**

إجابة نموذجية

نقارن ونشرح لماذا.

مثال محلول · تمرين · توقف وطبّق · الإجابة النموذجية ابحث عن هذه العلامات أعلى الشرائح.

حين ترى «توقف وطبّق»: أوقف الفيديو مؤقتاً، واكتب إجابتك في الكراسة قبل أن تنتقل إلى الإجابة النموذجية.

لمن هذا الكورس؟



خريج بلا خبرة

من أي تخصص: حاسب، أو نظم، أو إدارة، أو قانون، أو محاسبة.



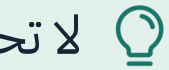
موظف تقنية يريد التحول

دعم فني، أو شبكات، أو تطوير، ويريد مساراً يجمع التقنية بالإدارة.



مختص تدقيق أو قانون أو جودة

يملك نصف المهارة، ويحتاج لغة الأمن السيبراني.



لا تحتاج خلفية في الأمن السيبراني. تحتاج فضولاً، وكتابة واضحة، واستعداداً للتطبيق.

خريطة الكورس: تسع وحدات من الفكرة إلى الوظيفة

المعرفة والتطبيق: الوحدات 1 إلى 5

01
ما هو GRC؟
الفكرة، والأدوار، ويوم العمل

02
الأساس التقني
هويات، وشبكات، وسحابة، وحماية

03
المفاهيم وتطبيقاتها
حوكمة، ومخاطر، وامتثال

04
الأطر والانطباق
ما الذي ينطبق، والمواءمة

05
الشهادات
لمن، ومتى، وكيف تختار

الوصول إلى الوظيفة: الوحدات 6 إلى 9

06
خطة البداية
مشاريع وملف أعمال

07
السيرة الذاتية
إنجازات تُقرأ

08
لينكدإن والفرص
ملف يجده الباحث

09
المقابلة والانطلاق
إجابات وخطة

الحالة العملية: شركة رُفاد

رُفاد للخدمات اللوجستية

شركة افتراضية متوسطة الحجم في الرياض، نحو 200 موظف، تقدم خدمات التوصيل والتخزين للمتاجر الإلكترونية.

شركة افتراضية

نظام الموارد البشرية والرواتب

خدمة سحابية. بيانات الموظفين ورواتبهم وحساباتهم البنكية. المالكة: مديرة الموارد البشرية.

البريد والملفات السحابية

منصة بريد وتخزين سحابية لكل الموظفين. المالك: مدير تقنية المعلومات.

تطبيق تتبع الشحنات

على خادم سحابي. أسماء المستلمين وهواتفهم وعناوينهم. المالك: مدير تقنية المعلومات.

↑ يدير خادم التطبيق عن بعد

شركة سَنَد للحلول التقنية
مورد افتراضي للدعم الفني وإدارة الخوادم عن بعد، بعقد سنوي.

رُفاد شركة افتراضية لأغراض التدريب. اسمها وأشخاصها وأنظمتها وبياناتها وأدلتها مختلقة، وأي تشابه مع جهة حقيقية غير مقصود.

رُفاد شركة خاصة ليست جهة حكومية ولا تابعة لجهة حكومية، ولا تملك بنية تحتية وطنية حساسة، فالضوابط الأساسية ECC-2:2024 غير ملزمة لها. في هذه الحالة التدريبية تبنّتها رُفاد طوعاً مرجعاً داخلياً.

من يفعل ماذا في رُفاد

الدور	الشخص	ماذا يفعل في الحالة
الرئيس التنفيذي	أ. خالد	صاحب الصلاحية: يعتمد السياسات ويقبل المخاطر
لجنة الأمن السيبراني	يرأسها الرئيس التنفيذي	تشرف وتتابع كل ربع سنة
مسؤولة GRC	أ. ريم	الخط الثاني: المنهجية والمتابعة والتقارير
محلل GRC متدرب	أنت	تساعد ريم في كل تطبيقات الكورس
مدير تقنية المعلومات	م. سلمان	يملك الأنظمة التقنية ويشرف على المورد
مديرة الموارد البشرية	أ. منى	مالكة نظام الموارد البشرية والرواتب
المدير المالي	أ. فهد	العقود والمشتريات

01 ما هو GRC؟

قبل المصطلحات والأطر: ما العمل الذي يقوم به مختص GRC، ولماذا تحتاجه كل جهة؟

بعد هذه الوحدة ستستطيع أن:

- تشرح GRC بثلاثة أسئلة وبمثال من رُفاد.
- تعرف لماذا تحتاجه الجهات، وأين يقع بين أدوار الأمن.
- تعرف شكل يوم العمل والمسميات المبتدئة.

ثلاث كلمات، وسؤال لكل منها

Governance

الحوكمة

من يقرر، وبأي قواعد، وكيف نتابع؟

ما تنتجه: سياسات معتمدة، ولجنة، وأدوار.

في رُفاد: الرئيس التنفيذي يعتمد سياسة الأمن السيبراني.

Risk

المخاطر

ما الذي قد يضرنا، وماذا نفعل حياله؟

ما تنتجه: سجل مخاطر وخطط معالجة.

في رُفاد: تقييم خطر حساب المورد المشترك.

Compliance

الامتثال

هل نلتزم، وكيف نثبت؟

ما تنتجه: تقييمات، وأدلة، وملاحظات.

في رُفاد: فحص أدلة مراجعة صلاحيات نظام الرواتب.

الحوكمة تضع القواعد، والمخاطر تحدد الأولويات، والامتثال يثبت التطبيق.

لماذا تحتاج كل جهة من يعمل في GRC؟

1

أنظمة وعقود

جهات كثيرة ملزمة بأنظمة وضوابط، والعملاء يطلبون التزامات في العقود. أحدٌ يجب أن يحول النص إلى تطبيق.

2

موارد محدودة

لا تستطيع جهة أن تحمي كل شيء بالقدر نفسه. تقييم المخاطر يحدد أين تبدأ.

3

ثقة تحتاج دليلاً

الجهات الرقابية والعملاء والشركاء يطلبون إثباتاً، لا وعداً.

وكل ذلك يخدم أهداف العمل. أهداف رُفاد:

- استمرار التوصيل
- حماية بيانات العملاء
- صحة الرواتب
- الالتزام بالعقود

أين يقع GRC بين أدوار الأمن السيبراني؟

الدور	السؤال الذي يجيب عنه	يوم العمل
GRC	هل نحمي ما يهم، وهل نلتزم ونثبت؟	سياسات، وتقييم مخاطر، وفحص أدلة، ومتابعة
مركز العمليات	هل يحدث هجوم الآن؟	فرز التنبيهات، والتحقيق، والتصعيد
اختبار الاختراق	كيف يمكن اختراقنا؟	اختبار الأنظمة وكتابة تقارير الثغرات
هندسة الأمن	كيف نبني الحماية؟	تصميم الضوابط التقنية وتشغيلها

مختص GRC لا ينفذ الضوابط التقنية بنفسه غالباً، لكنه يفهمها بما يكفي ليسأل الأسئلة الصحيحة ويقرأ الدليل.

المسميات التي ستراها في الإعلانات

المسمى الذي ستراه	ماذا يفعل غالباً	أين يعمل
محلل GRC أو محلل امتثال	تقييم فجوات، وأدلة، ومتابعة خطط	الخط الثاني
محلل مخاطر الأمن السيبراني	سجل المخاطر، والتقييم، والتقارير	الخط الثاني
مسؤول سياسات الأمن السيبراني	كتابة السياسات والمعايير ومراجعتها	الخط الثاني
مقيّم الضوابط الأمنية	اختبار الضوابط وجمع الأدلة	الثاني أو الثالث
مدقق تقنية معلومات مبتدئ	تدقيق مستقل وتقارير ملاحظات	الخط الثالث

المسميات تختلف بين الجهات. بعضها من فئة «الحوكمة والمخاطر والامتثال والأنظمة» في الإطار السعودي لكوادر الأمن السيبراني SCyWF-1.5:2026.

يوم في عمل محلل GRC مبتدئ في رُفاد

08:00 طلبات الأدلة: الموارد البشرية أرسلت ملف المراجعة، وتقنية المعلومات تأخرت.

09:00 متابعة خطة معالجة خطر المورد مع سلمان.

10:30 تحديث سجل المخاطر بخطر جديد من مشروع ترحيل نظام الرواتب.

12:00 فحص دليل: هل تكفي لقطة الإعداد، أم نطلب سجل التغييرات؟

14:00 مسودة إجراء إلغاء صلاحيات المغادرين.

15:30 شريحتان للجنة: المخاطر العالية والملاحظات المفتوحة.

مثال توضيحي مركّب. اليوم الفعلي يختلف حسب الجهة وحجمها وموسم التقييم.

أربع خرافات تؤخر البداية

الخرافة	الواقع
⚠ **«GRC أوراق وسياسات فقط»**	✓ السياسة بداية العمل. الجزء الأكبر هو التحقق من تطبيقها بالأدلة.
⚠ **«لا يحتاج معرفة تقنية»**	✓ تحتاج أساسيات تكفي لتسأل وتفهم الدليل: الهويات، والشبكات، والسجلات، والسحابة.
⚠ **«لا يدخله إلا أصحاب الخبرة»**	✓ توجد وظائف مبتدئة، والمشاريع العملية تعوض جزءاً من الخبرة.
⚠ **«تكفي شهادة واحدة»**	✓ الشهادة تفتح باب المقابلة. ما يقنع هو أن تشرح مثالاً عملياً.

صنّف مهام رُفاد: حوكمة أم مخاطر أم امتثال؟

#	المهمة في رُفاد	G أو R أو C؟
1	الرئيس التنفيذي يعتمد سياسة الأمن السيبراني	
2	تقدير احتمال وأثر سرقة حاسوب عليه ملفات الرواتب	
3	جمع أدلة مراجعة الصلاحيات لتقييم الالتزام بـ ECC	
4	تشكيل لجنة الأمن السيبراني وتحديد مهامها	
5	اختيار خطة معالجة لخطر حساب المورد المشترك	
6	مطابقة عقد المورد مع بنود ECC 4-1-2	

اكتب الحرف في الكراسة، وسبباً من جملة واحدة لكل مهمة. 4 دقائق.

الإجابة: G وR وC في مهام رُفاد

#	المهمة	الإجابة	لماذا
1	الرئيس التنفيذي يعتمد سياسة الأمن السيبراني	G	قرار ممن يملك الصلاحية يضع القواعد.
2	تقدير احتمال وأثر سرقة حاسوب عليه ملفات الرواتب	R	تحليل ما قد يحدث وحجمه لترتيب الأولوية.
3	جمع أدلة مراجعة الصلاحيات لتقييم الالتزام بـ ECC	C	إثبات تطبيق متطلب محدد بالأدلة.
4	تشكيل لجنة الأمن السيبراني وتحديد مهامها	G	هيكل إشراف ومسؤوليات ومتابعة.
5	اختيار خطة معالجة لخطر حساب المورد المشترك	R	قرار معالجة لخطر قُيّم مستواه.
6	مطابقة عقد المورد مع بنود ECC 4-1-2	C	مقارنة الوضع القائم بمتطلب مكتوب.

المهام متداخلة في الواقع: اعتماد خطة معالجة للخطر قرار حوكمة أيضاً. المهم أن تعرف السؤال الأساسي الذي تجيب عنه كل مهمة.

اختبار قصير: الوحدة 01

4

أسئلة قصيرة

8 دقائق

ما يغطيه الاختبار:

- ✓ الفرق بين الحوكمة والمخاطر والامتثال.
- ✓ أدوار الأمن السيبراني ومكان GRC بينها.
- ✓ لماذا تحتاج الجهات إلى GRC.

أوقف الفيديو، وأجب في الكراسة في قسم «اختبار الوحدة 01». ثم قارن بالإجابات المفسرة، وانتبه لسبب خطأ كل بديل.

02 الأساس التقني لمختص GRC

لا تحتاج أن تكون مهندساً، لكنك تحتاج أن تفهم ما تقيّمه. ستة موضوعات قصيرة، ولكل مفهوم أربعة أسئلة.

بعد هذه الوحدة ستستطيع أن:

- تشرح الهويات والشبكات والسحابة والحماية والتغيير بلغة بسيطة.
- تربط كل مفهوم تقني بخطره والضابط المناسب له.
- تعرف الدليل الذي تطلبه، ولماذا يقنع.

أربعة أسئلة لكل مفهوم تقني

ما هو؟

تعريف بجملة، بلا تفاصيل إعداد.

مثال: MFA: عامل ثانٍ مع كلمة المرور.

←

ما الخطر؟

ما الذي قد يحدث لو غاب أو ضعف؟

مثال: كلمة مرور مسروقة تكفي للدخول.

←

ما الضابط؟

ما الذي يعالج الخطر، ومن أي مرجع؟

مثال: MFA إلزامي للدخول عن بعد: ECC 2-2-3-2.

←

ما الدليل؟

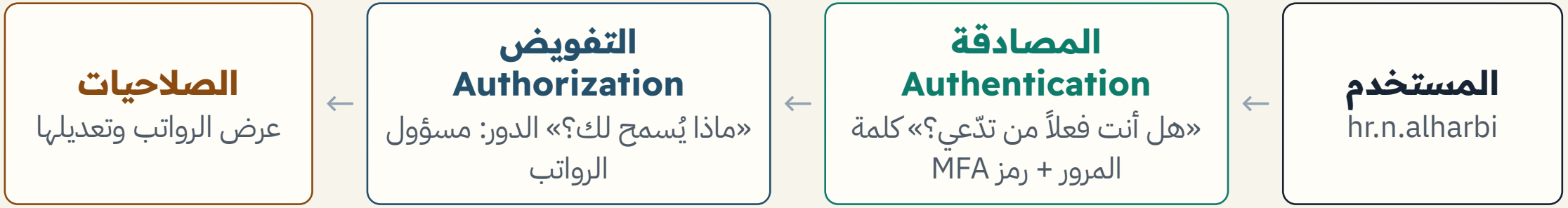
ما الذي ستطلبه لتتأكد أنه يعمل؟

مثال: إعداد السياسة، وسجل الدخول بطريقة التحقق.

الموضوعات الستة:

الهويات والصلاحيات · الدليل المركزي · الشبكات · السحابة · الحماية · التطبيقات والتغيير

الهويات: من أنت؟ وماذا يُسمح لك أن تفعل؟



حساب عادي

يستخدم النظام في عمله اليومي.

مثال: hr.n.alharbi، مسؤولة الرواتب.

حساب إداري (صلاحيات هامة)

يغيّر الإعدادات وصلاحيات الآخرين. أخطر ما يُسرق.

مثال: it.f.otaibi، «مدير النظام» في نظام الرواتب.

RBAC: الصلاحية للدور

تُعطى الصلاحيات للدور لا للشخص. يتغير الدور فتتغير الصلاحيات.

مثال: سعد الدوسري انتقل إلى العمليات في فبراير.

الهويات بالأسئلة الأربعة

المفهوم: ما هو؟	ما الخطر؟	الضابط المناسب	الدليل الذي تطلبه
الحساب الإداري: يغيّر الإعدادات وصلاحيات الآخرين.	سرقته سيطرة على النظام كله.	حسابات إدارية بأسماء أصحابها وتُدار صلاحياتها · ECC 2-2-3-4	قائمة الحسابات الإدارية ومالكيها، وسجل استخدامها.
MFA: عامل ثانٍ مع كلمة المرور.	كلمة مرور مسروقة تكفي للدخول.	MFA للدخول عن بعد وللحسابات الهامة · ECC 2-2-3-2	إعداد السياسة وتاريخه، وسجل الدخول بطريقة التحقق.
RBAC وأقل صلاحية: صلاحيات حسب الدور، وبقدر الحاجة.	صلاحيات زائدة تبقى بعد تغيير الدور.	أدوار معتمدة ومراجعة دورية · ECC 2-2-3-3 و2-2-3-5	مصفوفة الأدوار، وملف المراجعة المعتمد.
فصل المهام: لا يكمل شخص واحد عملية حساسة وحده.	من يعدّل الحساب البنكي ويعتمد المسير قد يختلس.	فصل الإدخال عن الاعتماد، وموافقة ثانية.	تقرير بمن يجمع دورين متعارضين.

الدليل المركزي: Active Directory وLDAP



LDAP: الطريقة التي تسأل بها الأنظمة الدليل: من هذا المستخدم؟ وإلى أي مجموعة ينتمي؟ لا تحتاج أكثر من هذا.

الخطر

حساب مغادر نشط يفتح كل ما يرتبط بالدليل، ومجموعة إدارية متضخمة.

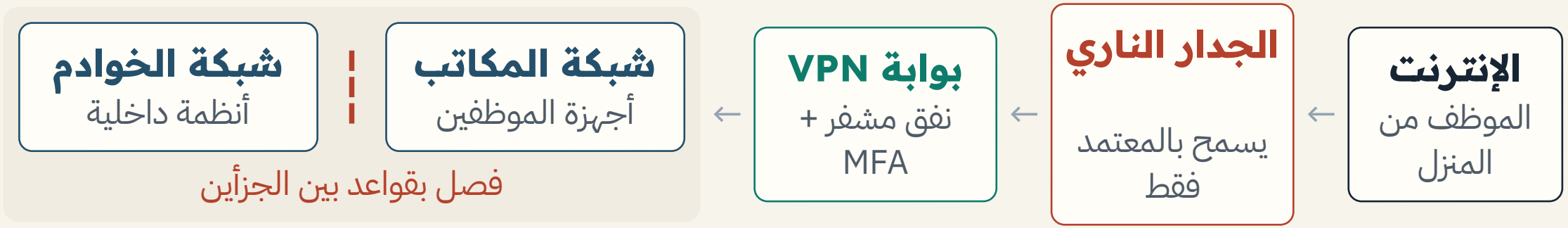
الضابط

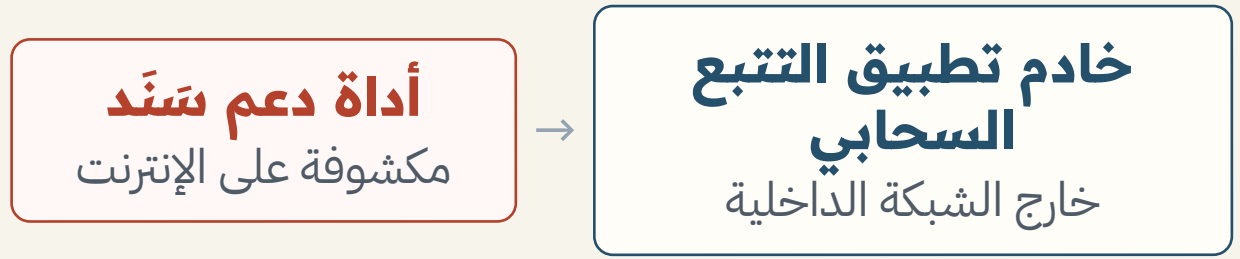
ربط الدليل بإجراء المغادرين، ومراجعة المجموعات الإدارية.

الدليل

الحسابات المعطلة مقابل قائمة المغادرين، وأعضاء المجموعات الإدارية.

الشبكات: من أين يدخل الاتصال، وأين يُسجَّل؟





السجلات: الجدار الناري وبوابة VPN والخوادم تسجل من دخل ومتى. بلا سجلات لا اكتشاف ولا تحقيق.

الشبكات بالأسئلة الأربعة

المفهوم: ما هو؟	ما الخطر؟	الضابط المناسب	الدليل الذي تطلبه
الجدار الناري: يسمح بالاتصالات المعتمدة فقط.	منفذ مفتوح بلا حاجة باب للمهاجم.	قواعد بمالك وسبب، وتقييد المنافذ · ECC 2-5-3-5	قائمة القواعد، وتاريخ آخر مراجعة.
VPN: نفق مشفر إلى الشبكة من الخارج.	كلمة مرور مسروقة تفتح الشبكة.	MFA ومجموعة محددة من المستخدمين · ECC 2-2-3-2	إعداد البوابة، وسجل الاتصالات.
فصل الشبكات: أجزاء بقواعد بينها.	اختراق جهاز واحد يصل إلى الخوادم.	فصل بالجدار الناري، والإنتاج عن الاختبار · ECC 2-5-3-1 و2-5-3-2	مخطط الشبكة، وقواعد العبور.
السجلات: من دخل، ومتى، وماذا فعل.	هجوم لا يُكتشف ولا يُحقق فيه.	للأصول المهمة والدخول عن بعد، وحفظ 12 شهراً · ECC 2-12-3	إعداد التسجيل، وعينة من الفترة.

السحابة: من المسؤول عن ماذا؟

الطبقة	IaaS · خادم تطبيق التتبع	PaaS · منصة لتشغيل تطبيق	SaaS · الرواتب والبريد
البيانات وتصنيفها	**الجهة**	**الجهة**	**الجهة**
الحسابات والصلاحيات	**الجهة**	**الجهة**	**الجهة**
التطبيق	**الجهة**	**الجهة**	المزود
نظام التشغيل والتحديثات	**الجهة**	المزود	المزود
الخوادم والشبكة والمراكز	المزود	المزود	المزود

الخطر

أن تفترض الجهة أن المزود يحمي كل شيء.

الضابط

مسؤوليات مكتوبة في العقد، وحماية البيانات وإعادتها عند الإنهاء (ECC 4-2-3).

الدليل

العقد وملحق المسؤوليات، وتقارير المزود، وإعداد الحسابات من جهة رُفاد.

التقسيم الدقيق في عقد كل مزود ووثائقه. لكن البيانات والحسابات تبقى مسؤولية الجهة في كل النماذج.

الحماية: أربعة ضوابط ستسأل عنها كثيراً

المفهوم: ما هو؟	ما الخطر؟	الضابط المناسب	الدليل الذي تطلبه
الثغرات والتحديثات: فحص دوري، وتحديث حسب الخطورة.	ثغرة معروفة يستغلها مهاجم.	معالجة بمهل حسب الخطورة، واختبار قبل الإنتاج · ECC 2-10-3	تقرير الفحص، والثغرات المفتوحة بأعمارها.
التشفير: بيانات لا تُقرأ بلا مفتاح.	جهاز مسروق يكشف البيانات.	تشفير المخزن والمنقول حسب التصنيف · ECC 2-8-3	تقرير حالة التشفير للأجهزة.
النسخ الاحتياطي: نسخ دورية تُستعاد عند الفقد.	نسخ لا تُستعاد عند الحاجة.	نطاق للأصول المهمة، واختبار دوري للاستعادة · ECC 2-9-3	تقرير المهام، ومحضر اختبار استعادة.
DLP: يكتشف خروج البيانات الحساسة ويمنعه.	ملفات الرواتب تُرسل إلى بريد خارجي.	تصنيف البيانات، ثم قواعد منع · ضمن ECC 2-7	القواعد المفعلة، وتقرير التنبيهات.

التطبيقات والتغيير: من التطوير إلى الإنتاج

التطوير Dev
يُكتب الكود · بيانات وهمية

←

الاختبار Test
يُجرَّب التغيير · بيانات غير حقيقية

←

الإنتاج Prod
يخدم المتاجر · بيانات حقيقية

إدارة التغيير: كل تغيير على الإنتاج يمر بست خطوات

طلب	تقييم الأثر	اعتماد	اختبار	تنفيذ	مراجعة

في رُفاد: سجل بوابة VPN في 10 مارس يبين إنشاء سياسة استثناء بعد تفعيل MFA بدقائق، بلا طلب تغيير ولا موافقة. ستراه دليلاً في التطبيق 3.

التطبيقات بالأسئلة الأربعة

المفهوم: ما هو؟	ما الخطر؟	الضابط المناسب	الدليل الذي تطلبه
فصل البيئات: التطوير والاختبار والإنتاج منفصلة.	تغيير غير مختبر يعطل الإنتاج.	فصل الإنتاج، وبيانات غير حقيقية للاختبار · ECC 2-5-3-2	مخطط البيئات، ومن يصل إلى كل بيئة.
إدارة التغيير: كل تغيير يُطلب ويُعتمد ويُختبر.	تغيير غير معتمد يفتح ثغرة.	إجراء تغيير، ومراجعة الإعداد الآمن قبل الإطلاق · ECC 1-6-2	تذاكر بموافقاتها، ومطابقتها بسجل التغييرات.
التطوير الآمن: الأمن جزء من كتابة الكود.	ثغرة في الكود تكشف بيانات المستلمين.	كود آمن، ومكتبات موثوقة، واختبار قبل الإطلاق · ECC 1-6-3	المعيار، ونتائج اختبار الأمن.

تمرين: المفهوم والخطر والضابط والدليل

لكل موقف: ما المفهوم التقني؟ ما الخطر؟ ما الضابط المناسب؟ وما الدليل الذي ستطلبه؟ 10 دقائق.

#	الموقف في رُفاد	المفهوم والخطر	الضابط والدليل
1	في نظام الرواتب، يستطيع موظفان في الموارد البشرية تعديل الحساب البنكي للموظف واعتماد مسير الرواتب كليهما.		
2	طُبّق تحديث على خادم تطبيق التتبع مساء خميس مباشرة، دون طلب تغيير ولا اختبار، فتوقف التتبع ساعتين.		
3	سجلات الدخول إلى البريد السحابي تُحفظ 90 يوماً فقط، ولا أحد يراجعها.		

الإجابة: المفهوم والخطر والضابط والدليل

المفهوم	الخطر	الضابط	الدليل
1. فصل المهام	موظف واحد يغيّر الحساب البنكي ثم يعتمد المسير، فيحوّل راتباً إلى حساب آخر دون أن يُكتشف.	فصل التعديل عن الاعتماد، وموافقة ثانية على تغيير الحساب البنكي، وتقرير شهري بالتغييرات.	مصفوفة الأدوار في النظام، وتقرير بمن يجمع الصلاحيتين، وعينة من تغييرات الحسابات البنكية بموافقاتها.
2. إدارة التغيير وفصل البيئات	تغيير غير مختبر يوقف خدمة يعتمد عليها العملاء، أو يفتح ثغرة.	إجراء تغيير: طلب، وتقييم أثر، واعتماد، واختبار في بيئة غير الإنتاج، ونافذة تنفيذ محددة.	تذكرة التغيير بموافقتها ونتيجة اختباره، ومطابقة سجل تغييرات الخادم بالتذاكر.
3. السجلات	حادثة قديمة لا يمكن التحقيق فيها، ودخول مشبوه لا يكتشفه أحد.	حفظ السجلات 12 شهراً على الأقل (ECC 2-12-3-5)، ومراقبة مستمرة أو مراجعة منتظمة للتنبيهات.	إعداد مدة الحفظ في الخدمة، وأقدم سجل متاح، وتقرير المراقبة أو المراجعة.

اختبار قصير: الوحدة 02

5

أسئلة قصيرة

10 دقائق

ما يغطيه الاختبار:

- ✓ المصادقة والتفويض وفصل المهام.
- ✓ المسؤولية المشتركة في السحابة.
- ✓ أدلة النسخ الاحتياطي وإدارة التغيير.

أوقف الفيديو، وأجب في الكراسة في قسم «اختبار الوحدة 02». ثم قارن بالإجابات المفسرة، وانتبه لسبب خطأ كل بديل.

03 المفاهيم وتطبيقاتها

أطول وحدة وأهمها: ثلاثة أجزاء، وأربعة تطبيقات تنفذها بنفسك على رُفاد.

بعد هذه الوحدة ستستطيع أن:

- تحدد المسؤوليات بمصفوفة RACI، وتكتب بند سياسة من متطلب.
- تكتب خطراً وتقيمه بمصفوفة الإطار الوطني، وتحدد معالجته.
- تفحص أدلة ضابط، وتميز فجوة التصميم من التنفيذ والتشغيل، وتكتب ملاحظة وخطة تصحيح.
- تعرّف مؤشرات، وتقرأ تقريراً للإدارة بصفحة واحدة.

الجزء الأول

الحوكمة

من يقرر، وبأي قواعد، ومن المسؤول عن ماذا؟

- الحوكمة والإدارة والتشغيل
- الأدوار والمسؤوليات
- نموذج الخطوط الثلاثة
- هرم الوثائق ودورة حياة السياسة
- مصفوفة RACI
- التطبيق 1: مسؤوليات وبند سياسة

الحوكمة والإدارة والتشغيل: قرار واحد بثلاثة مستويات

الحوكمة
صاحب الصلاحية واللجنة

ماذا نريد، ولماذا، ومن يحاسب؟
في رُفاد: اعتماد قرار: التحقق متعدد العوامل إلزامي للدخول عن بعد.

↓

الإدارة
مدراء الإدارات

كيف ننفذ القرار، وبأي موارد وجدول؟
في رُفاد: خطة نشر خلال 6 أسابيع، وميزانية، ومسؤول لكل مرحلة.

↓

التشغيل
الفرق والمورد

من ينفذ العمل يومياً؟
في رُفاد: تسجيل أجهزة الموظفين في تطبيق التحقق.

ثم تعود الحوكمة لتتابع: هل تحقق ما قررناه؟ وما نسبة الحسابات المفعّل عليها التحقق؟

صنّف أنشطة رُفاد: حوكمة أم إدارة أم تشغيل؟

#	النشاط في رُفاد	حوكمة أم إدارة أم تشغيل؟
1	اعتماد قرار: «التحقق متعدد العوامل إلزامي للدخول عن بعد»	
2	خطة نشر التحقق متعدد العوامل خلال 6 أسابيع وميزانيتها	
3	تسجيل جهاز الموظف في تطبيق التحقق	
4	تقرير ربع سنوي للجنة عن نسبة الحسابات المفعّل عليها التحقق	

اكتب المستوى وسبباً قصيراً لكل نشاط. 3 دقائق.

الإجابة: مستويات أنشطة رُفاد

#	النشاط	المستوى	لماذا
1	اعتماد قرار: «التحقق متعدد العوامل إلزامي للدخول عن بعد»	حوكمة	قرار وتوجه يعتمده صاحب الصلاحية.
2	خطة نشر التحقق متعدد العوامل خلال 6 أسابيع وميزانيتها	إدارة	تخطيط الموارد والجدول لتنفيذ القرار.
3	تسجيل جهاز الموظف في تطبيق التحقق	تشغيل	تنفيذ يومي للإجراء.
4	تقرير ربع سنوي للجنة عن نسبة الحسابات المفعّل عليها التحقق	حوكمة	متابعة وإشراف ومساءلة من الجهة الأعلى.

النشاط الرابع يخدع كثيرين: التقرير للجنة ليس عملاً إدارياً عادياً، بل متابعة وإشراف، وهما جزء من الحوكمة.

من يقرر، ومن يملك، ومن يتحقق في رُفاد

صاحب الصلاحية

الرئيس التنفيذي خالد

يعتمد السياسات ويقبل المخاطر

اللجنة

لجنة الأمن السيبراني

تشرف، وتتابع، وتوصي

مالك النظام ومالك الخطر

منى · نظام الرواتب

مسؤولة عن النظام وبياناته، وتقرر معالجة خطر ملفات الرواتب

GRC

ريم، وأنت معها

تضع المنهجية، وتراقب، وتبلغ

مالك الضابط

سلمان · التحقق متعدد العوامل

يطبق الضابط ويحتفظ بأدلته

GRC لا ينفذ كل الضوابط، ولا يملك كل المخاطر

ما يفعله GRC

- يضع المنهجية والنماذج.
- يساعد الإدارات على فهم المتطلبات.
- يتحقق من التطبيق بالأدلة.
- يرفع الصورة بوضوح للإدارة واللجنة.

ما لا يفعله GRC

- لا ينفذ كل الضوابط بنفسه.
- لا يملك مخاطر الإدارات الأخرى.
- لا يعتمد السياسات بدل صاحب الصلاحية.
- لا يتحمل الخطأ عن كل الجهة.

في رُفاد: ريم لا تعطّل حسابات المغادرين. سلمان يعطّلها، وريم تتحقق أن ذلك يحدث فعلاً.

نموذج الخطوط الثلاثة في رُفاد

جهة الحوكمة: الرئيس التنفيذي ولجنة الأمن السيبراني، تحدد التوجه وتحاسب.

الخط الأول

الإدارات التشغيلية

تملك المخاطر وتطبق الضوابط. في رُفاد: سلمان ومنى والمورد تحت إشرافهما.

الخط الثاني

المخاطر والامتثال

يضع الإطار ويراقب ويتحدى. في رُفاد: ريم، وأنت معها.

الخط الثالث

المراجعة الداخلية

تأكيد مستقل. في رُفاد: مراجع خارجي متعاقد معه سنوياً.

النموذج من معهد المدققين الداخليين IIA. توزيع الأدوار يختلف من جهة لأخرى.

هرم الوثائق: من «لماذا» إلى «كيف»

السياسة
ماذا ولماذا · يعتمدها صاحب الصلاحية

«تُراجع الصلاحيات دورياً في كل الأنظمة.»

المعيار
قيم ملزمة قابلة للقياس

«نظام الرواتب: مراجعة كل 3 أشهر، وإزالة خلال 5 أيام عمل.»

الإجراء
خطوات: من يفعل ماذا ومتى

«تصدّر تقنية المعلومات القائمة، ثم يؤكد كل مدير...»

الإرشاد
توصيات غير ملزمة

«يُنصح بمراجعة الحسابات غير المستخدمة منذ 90 يوماً أولاً.»

مثال واحد عبر المستويات الأربعة: مراجعة الصلاحيات في رُفاد. القيم مثال تدريبي.

مكونات السياسة: سياسة واحدة كاملة

سياسة

نموذج تعليمي · بيانات افتراضية

سياسة التحكم بالوصول

الرمز: POL-AC-01 الإصدار: 2.0 الاعتماد: الرئيس التنفيذي · 15 يناير 2026 المالك: مسؤولة GRC

1. الغرض	حماية الأنظمة والبيانات بمنح الوصول بقدر الحاجة، ومراجعته وإلغائه.
2. النطاق	كل أنظمة رُفاد وحساباتها، والموظفون والمتعاقدون والمورد سَنَد.
3. الأدوار	مالك كل نظام يعتمد الصلاحيات، وتقنية المعلومات تنفذ، وGRC تتابع.
4. المتطلبات	4.1 حسابات مسماة · 4.2 MFA للدخول عن بعد · 4.3 المراجعة الدورية · 4.5 المغادرون.
5. الاستثناءات	بموافقة موثقة من مالك النظام وGRC، ولمدة محددة.
6. الاعتماد والمراجعة	يعتمدها الرئيس التنفيذي، وتُراجع سنوياً أو عند تغيير مهم.

1. **لماذا ولمن؟**
   الغرض والنطاق يحددان ما تغطيه السياسة.
2. **من يفعل ماذا؟**
   الأدوار بالوظيفة، والمتطلبات ما يُطلب دليله.
3. **متى نخرج عنها؟**
   استثناء بموافقة ومدة، لا بقرار فردي.
4. **من يعتمد، ومتى تُراجع؟**
   إصدار وتاريخ وصاحب صلاحية.

دورة حياة السياسة: سبع مراحل

1 تحديد الحاجة والمتطلبات
نظام، أو ضابط، أو خطر، أو حادثة.

2 الصياغة
مسودة بلغة واضحة وقابلة للتدقيق.

3 المراجعة
الإدارات المعنية والقانونية وGRC.

4 الاعتماد
من صاحب الصلاحية، بتاريخ وإصدار.

5 النشر
لمن تنطبق عليهم، مع توعية.

6 التطبيق
إجراءات وضوابط وأدلة.

7 المراجعة الدورية
سنوياً أو عند التغيير.

ثم تعود الدورة من البداية

في رُفاد: سياسة التحكم بالوصول تُراجع سنوياً، أو فوراً عند تغيير نظام مهم مثل ترحيل نظام الرواتب.

أمن العاملين: الانضمام وتغيير الدور والمغادرة

الانضمام

بنود المسؤوليات والسرية في العقد، وتوعية عند البدء، وصلاحيات حسب الدور.

في رُفاد: لا يحصل الموظف الجديد على حساب الرواتب قبل طلب معتمد من مديره.

الدليل: عقد موقّع، وسجل إكمال التوعية، وطلب الصلاحيات.

تغيير الدور

تُضاف صلاحيات الدور الجديد، وتُزال صلاحيات القديم في الوقت نفسه.

في رُفاد: سعد الدوسري انتقل إلى العمليات في فبراير، وبقيت معه صلاحية «تعديل الرواتب» حتى 20 مايو.

الدليل: طلب النقل، وتذكرة تعديل الصلاحيات بتاريخها.

المغادرة

مراجعة الصلاحيات وإلغاؤها مباشرة، واستعادة الأصول، وتذكير بالسرية.

في رُفاد: هذا موضوع التطبيق 1: من يُبلَّغ، ومن يلغي، ومن يتحقق.

الدليل: إشعار الموارد البشرية، وتذاكر الإلغاء، ومحضر استلام الأصول.

التوعية ليست محاضرة سنوية فقط: عند الانضمام وخلال العمل، ويُقاس إكمالها.

مصفوفة RACI: أربعة حروف قبل أن نبدأ

R المنفّذ
Responsible

من يقوم بالعمل فعلاً. قد يكونون أكثر من واحد.

C المستشار
Consulted

يؤخذ رأيه قبل التنفيذ: تواصل باتجاهين.

A المساءَل
Accountable

من يحاسَب على النتيجة ويعتمدها. واحد فقط.

I المُبلَّغ
Informed

يُخبر بالنتيجة بعد التنفيذ: اتجاه واحد.

قاعدة واحدة تمنع أغلب الأخطاء: A واحد لكل نشاط. وقد يكون الشخص نفسه A وR معاً.

من متطلب إلى بند سياسة: أربع خطوات

1
اقرأ المتطلب
ماذا يطلب بالضبط؟

←

2
حدد قرار الجهة
النطاق والمدة والمسؤول.

←

3
اكتب البند
جملة إلزامية واضحة.

←

4
اختبره
هل يمكن تدقيقه بدليل؟

معايير البند الجيد

- ✓ يحدد النطاق: أي أنظمة أو أشخاص.
- ✓ يحدد المسؤول بالوظيفة.
- ✓ يحدد المدة أو التكرار.
- ✓ بصيغة إلزامية: «يجب» أو «تُ...».
- ✓ ينتج دليلاً يمكن طلبه.
- ✓ لا يكرر نص الضابط حرفياً.

مثال محلول: المتطلب وقرار الجهة

> ECC 2-2-3-5: يجب أن تغطي متطلبات إدارة هويات الدخول والصلاحيات بحد أدنى: المراجعة الدورية لهويات الدخول والصلاحيات.

الوضع في رُفاد

نظام الموارد البشرية والرواتب فيه 214 حساباً، ولا توجد مراجعة دورية للصلاحيات حتى الآن.

قرار رُفاد

قررت رُفاد مراجعة ربع سنوية لهذا النظام لأنه يحتوي رواتب الموظفين وحساباتهم البنكية. الضابط يقول «دورية» ولا يحدد المدة؛ الجهة تحددها بناءً على المخاطر وتوثقها.

⚠ الضابط لا يحدد المدة. لا تخترع رقماً «من الضابط»؛ اكتب أنه قرار الجهة ومبرره.

مثال محلول: مصفوفة RACI لمراجعة الصلاحيات

R ينفّذ **A** يُحاسَب، واحد فقط **C** يُستشار قبل **I** يُبلَّغ بعد

النشاط	مالكة النظام	مدير الموظف	تقنية المعلومات	GRC
تصدير قائمة المستخدمين وصلاحياتهم	A		R	I
تأكيد حاجة كل موظف لصلاحيته	A	R		C
اعتماد نتيجة المراجعة	A/R	I	I	I
إزالة الصلاحيات غير المبررة	I		A/R	I
متابعة الإنجاز وحفظ الأدلة	A		C	R

A واحد في كل صف. GRC يتابع ويحفظ الأدلة، ولا ينفذ الإزالة.

مثال محلول: البند في صفحة السياسة

سياسة

نموذج تعليمي · بيانات افتراضية

سياسة التحكم بالوصول

الرمز: POL-AC-01 الإصدار: 2.0 الاعتماد: الرئيس التنفيذي · 15 يناير 2026 المالك: مسؤولة GRC

4.3 المراجعة الدورية للصلاحيات

1. يحقق هذا البند: ECC 2-2-3-5، المراجعة الدورية لهويات الدخول والصلاحيات.
2. تُراجع هويات الدخول والصلاحيات في نظام الموارد البشرية والرواتب كل ثلاثة أشهر على الأقل.
3. تعتمد مالكة النظام نتيجة المراجعة خلال 10 أيام عمل من تصدير القائمة، وتُزال الصلاحيات غير المبررة خلال 5 أيام عمل من الاعتماد،
4. وتُحفظ أدلة المراجعة والإزالة سنتين على الأقل.

1. **المتطلب**
   البند يذكر الضابط الذي يحققه، فيسهل ربطه في التقييم.
2. **النطاق والتكرار**
   نظام محدد، وكل ثلاثة أشهر: قرار رُفاد، لا رقم من الضابط.
3. **المسؤول والمدد**
   مالكة النظام بالوظيفة، ومهلتان قابلتان للقياس.
4. **دليل التطبيق**
   ما سيُطلب في التقييم: ملف المراجعة وأدلة الإزالة.

مثال محلول: المعيار للموضوع نفسه

معيار

نموذج تعليمي · بيانات افتراضية

معيار التحكم بالوصول

الرمز: STD-AC-01 الإصدار: 1.0 الاعتماد: 15 يناير 2026 المالك: مدير تقنية المعلومات

مراجعة صلاحيات نظام الموارد البشرية والرواتب

1. التكرار: مراجعة كل 3 أشهر.
2. الاعتماد: تعتمد مالكة النظام النتيجة خلال 10 أيام عمل من التصدير.
3. الإزالة: خلال 5 أيام عمل من الاعتماد، بتذكرة لكل إزالة.
4. الأدلة: ملف المراجعة المعتمد، وتذاكر الإزالة، تُحفظ سنتين.

1. **قيمة قابلة للقياس**
   المعيار يحول «دورياً» إلى رقم.
2. **مهلة الاعتماد**
   تُحسب بأيام العمل من تاريخ التصدير.
3. **مهلة الإزالة ودليلها**
   لكل إزالة تذكرة بتاريخ فتح وإغلاق.
4. **ما يُحفظ**
   هذه هي الأدلة التي ستفحصها في التطبيق 3.

مثال محلول: الإجراء للموضوع نفسه

إجراء

نموذج تعليمي · بيانات افتراضية

إجراء المراجعة الفصلية للصلاحيات

الرمز: PRC-AC-03 الإصدار: 1.0 المالك: مالكة النظام

الخطوات

1. تقنية المعلومات: تصدّر قائمة المستخدمين وصلاحياتهم من النظام.
- 2. مدير كل موظف: يؤكد حاجة موظفيه لصلاحياتهم، أو يطلب إزالتها.
2. مالكة النظام: تعتمد النتيجة خلال 10 أيام عمل من التصدير.
3. تقنية المعلومات: تزيل غير المبرر خلال 5 أيام عمل، بتذكرة لكل حساب.
4. GRC: تتابع الإنجاز، وتحفظ ملف المراجعة والتذاكر.

1 **من يبدأ**
كل خطوة بمسؤول بالوظيفة، كما في مصفوفة RACI.

2 **المهلة من المعيار**
الإجراء لا يخترع أرقاماً جديدة.

3 **أثر يمكن طلبه**
التذكرة تثبت الإزالة وتاريخها.

4 **حفظ الأدلة**
GRC يتابع ويحفظ، ولا ينفذ الإزالة.

دورك: إلغاء صلاحيات المغادرين

ECC 1-9-5: يجب مراجعة وإلغاء الصلاحيات للعامل مباشرة بعد انتهاء/إنهاء العلاقة الوظيفية مع الجهة.

ما وجدته في رُفاد

- تسجل الموارد البشرية الاستقالات في نظام الموارد البشرية والرواتب.
- تعرف تقنية المعلومات بالمغادرين عبر رسائل غير رسمية من المدراء.
- المورد سَنَد يعطل حساب البريد حين تطلب منه تقنية المعلومات ذلك.
- لا أحد يتحقق من حسابات نظام الرواتب وتطبيق التتبع والوصول عن بعد.
- الشهر الماضي غادر 4 موظفين، وبقي حسابان منهم نشطين بعد 3 أسابيع.

دورك: المطلوب

1. اكتب خمسة أنشطة لعملية إلغاء صلاحيات المغادرين.
2. املأ مصفوفة RACI، مع مسؤول A واحد لكل نشاط.
3. اكتب بند سياسة من جملتين أو ثلاث يحقق معايير البند الجيد.

تذكّر معايير البند الجيد

- ✓ يحدد النطاق: أي أنظمة أو أشخاص.
- ✓ يحدد المسؤول بالوظيفة.
- ✓ يحدد المدة أو التكرار.
- ✓ بصيغة إلزامية: «يجب» أو «تُ...».
- ✓ ينتج دليلاً يمكن طلبه.
- ✓ لا يكرر نص الضابط حرفياً.

دورك: النموذج

النشاط	الموارد البشرية	مدير الموظف	تقنية المعلومات	GRC
النشاط 1				
النشاط 2				
النشاط 3				
النشاط 4				
النشاط 5				

بند السياسة

اكتب جملتين أو ثلاثاً هنا...

النموذج كاملاً في الكراسة. 15 دقيقة.

الإجابة: مصفوفة RACI لإلغاء صلاحيات المغادرين

R ينفّذ **A** يُحاسَب، واحد فقط **C** يُستشار قبل **I** يُبلَّغ بعد

النشاط	الموارد البشرية	مدير الموظف	تقنية المعلومات	GRC
إشعار انتهاء العلاقة الوظيفية فور تحديد آخر يوم عمل	A/R	C	I	
إلغاء الحسابات والصلاحيات في كل الأنظمة	I	I	A/R	
توثيق الإلغاء في تذكرة مغلقة بأدلتها	I		A/R	I
مطابقة شهرية: المغادرون مقابل الحسابات النشطة	C		A/R	I
مراقبة فاعلية الإجراء وإبلاغ اللجنة	C		C	A/R

المورد ينفذ الإلغاء تحت إشراف تقنية المعلومات، فهي المساءلة. المسؤولية لا تنتقل إلى المورد.

الإجابة: بند السياسة ولماذا

سياسة

سياسة التحكم بالوصول

نموذج تعليمي · بيانات افتراضية

البند: 4.5 إلغاء صلاحيات المغادرين يحقق: ECC 1-9-5

1. يجب إلغاء جميع حسابات العامل وصلاحياته في أنظمة رُفاد، بما فيها حسابات الوصول عن بعد، في موعد أقصاه نهاية آخر يوم عمل له.
2. تُشعر الموارد البشرية تقنية المعلومات فور تحديد آخر يوم عمل، وتنفذ تقنية المعلومات الإلغاء وتوثقه في تذكرة،
3. وتطابق شهرياً قائمة المغادرين مع الحسابات النشطة.

1 النطاق والموعد

كل الأنظمة، ونهاية آخر يوم عمل تحقق كلمة «مباشرة».

2 المسؤول والدليل

الموارد البشرية تُشعر، وتقنية المعلومات تنفذ وتوثق في تذكرة.

3 ضابط كشفي

المطابقة الشهرية تلتقط ما فات، ويملكها الخط الأول لا GRC.

التطبيق 1: أخطاء شائعة

كيف تتجنبها

- A واحد في كل صف، وراجع الصفوف بعد التعبئة.
- الخط الأول ينفذ، وGRC يتحقق.
- موعد محدد ومسؤول بالوظيفة ودليل.
- غطّ كل الأنظمة، بما فيها الوصول عن بعد.
- البند يقول كيف ستلتزم الجهة، لا يكرر الضابط.

أخطاء شائعة

- وضع GRC مسؤولاً عن تعطيل الحسابات.
- أكثر من A في النشاط الواحد، أو نشاط بلا A.
- بند غامض: «تُلغى الصلاحيات في الوقت المناسب».
- نسيان حسابات الوصول عن بعد ونظام الرواتب وتطبيق التتبع.
- نسخ نص الضابط كما هو دون تحديد من ومتى وما الدليل.

الجزء الثاني

المخاطر

ما الذي قد يحدث، وما حجمه، وماذا نفعل حياله؟

ثلاثية الأمن
مصطلحات المخاطر
صياغة الخطر
الإطار الوطني لإدارة المخاطر
مصفوفة التقييم
المتأصل والمتبقي
المعالجة والشهية
الضوابط
سجل المخاطر
التطبيق 2

ثلاثية الأمن: ما الذي نحميه في المعلومات؟

السرية Confidentiality

لا يطّلع على المعلومة إلا المخوَّل.

ما يهددها في رُفاد: تسرب ملف الرواتب.

ما يحميها: الصلاحيات والتشفير.

السلامة Integrity

المعلومة صحيحة ولم تُغيَّر دون إذن.

ما يهددها في رُفاد: تغيير رقم الحساب البنكي لموظف في نظام الرواتب.

ما يحميها: فصل المهام وسجلات التغيير.

التوافر Availability

الخدمة متاحة وقت الحاجة.

ما يهددها في رُفاد: توقف تطبيق التتبع يوم ذروة.

ما يحميها: النسخ الاحتياطي وخطة التعافي.

في كل خطر اسأل: أي الثلاثة يمس؟ الإجابة تحدد الضابط المناسب وحجم الأثر.

ستة مصطلحات للمخاطر، بمثال واحد

الأصل
ما له قيمة للجهة.
مثال: الحاسوب وملفات الرواتب.

+

التهديد
ما قد يسبب الضرر.
مثال: سرقة الحاسوب من السيارة.

+

الثغرة
ضعف يسهّل الضرر.
مثال: القرص غير مشفر.

↓

الخطر
تهديد يستغل ثغرة في أصل.
«تسرب الرواتب بسرقة حاسوب غير مشفر».

الاحتمال
فرصة الحدوث خلال فترة.
مثال: الموظف يتنقل بالحاسوب يومياً.

×

الأثر
حجم الضرر إن حدث.
مثال: تسرب رواتب كل الموظفين.

=

مستوى الخطر
ما يرتب الأولوية.
مثال: نقيسه بمصفوفة الإطار الوطني.

كيف نكتب الخطر: سبب، وحدث، وأثر

بسبب... (الثغرة أو السبب) قد... (الحدث) مما يؤدي إلى... (الأثر)

بسبب حفظ ملفات تصدير الرواتب على حاسوب محمول غير مشفر، قد يؤدي فقدانه أو سرقته إلى اطلاع غير مصرح به على رواتب 200 موظف وحساباتهم البنكية، مما يضر الموظفين ويعرض رُفاد لمخالفة نظام حماية البيانات الشخصية ولضرر في سمعتها.

صياغة جيدة

- سبب، وحدث، وأثر في جملة واحدة.
- يفهمها مالك الخطر دون شرح.

صياغة ضعيفة

- «لا يوجد تشفير». هذه ثغرة.
- «خطر أمني على الحاسوب». بلا حدث ولا أثر.

من أين نكتشف المخاطر؟ سجل الأصول، والحوادث السابقة، وتقارير الثغرات، والتدقيق، والتغييرات والمشاريع، والموردون.

الإطار الوطني لإدارة مخاطر الأمن السيبراني

الاسم والإصدار الإطار الوطني لإدارة مخاطر الأمن السيبراني NFCRM-1:2025، صدر 23 يوليو 2025.

على من ينطبق الجهات الحكومية وما يتبعها، وجهات القطاع الخاص التي تملك أو تشغل أو تستضيف بنية تحتية وطنية حساسة.

في رُفاد غير ملزم لها. تبنت مصفوفته طوعاً في الحالة التدريبية.

1 التحديد

الأصول، والثغرات، والتهديدات، والسيناريوهات، والضوابط الحالية.

← **2 التقييم**

الاحتمال والأثر بالمصفوفة، والتوثيق في السجل.

← **3 المعالجة**

قبول، أو مشاركة، أو تخفيف، أو تجنب، بخطط وأولويات.

← **4 المتابعة**

تقارير، ومراقبة الخطط، وإعادة التقييم عند التغيير.

مستويات الاحتمال في الإطار الوطني

القيمة	المستوى	الإطار الزمني	أو: سهولة الاستغلال
5	شبه مؤكد	يتكرر غالباً، عدة مرات في السنة.	يستغله مهاجم غير محترف بأداة جاهزة.
4	محتمل	يحدث غالباً مرة في السنة.	يستغله مهاجم متقدم بأدوات خاصة.
3	غير مرجح	قد يحدث مرة كل 2 إلى 3 سنوات.	يستغله متقدم بشروط محددة فقط.
2	نادر	مرة كل 3 إلى 10 سنوات.	غير قابل للاستغلال مباشرة الآن.
1	نادر جداً	أقل من مرة كل 10 إلى 20 سنة.	لا يُعد قابلاً للاستغلال حالياً.

ملخص من الشكل 5 في NFCRM-1:2025. يُختار المستوى بالإطار الزمني أو بسهولة الاستغلال.

مستويات الأثر في الإطار الوطني

القيمة	المستوى	الأثر عند المساس بالسرية أو السلامة أو التوافر
5	حرج	أثر كبير لا تحتمله الجهة، أو أثر على المستوى الوطني.
4	عالٍ	أثر كبير على الجهة.
3	متوسط	أثر ملموس على الجهة.
2	منخفض	أثر طفيف على الجهة.
1	منخفض جداً	لا أثر على الجهة، أو بيانات غير حساسة.

في رُفاد: تسرب رواتب وحسابات 200 موظف أثر كبير على الجهة، فهو «عالٍ» (4).

ملخص من الشكل 4 في NFCRM-1:2025، ويصف الإطار كل مستوى للسرية والسلامة والتوافر منفصلة.

المصفوفة: الاحتمال × الأثر

مثال الحاسوب

الاحتمال 3 × الأثر 4 = 12

12 يقع بين 8 و14: «متوسط».

حسب قاعدة رُفاد: خطة معالجة، أو قبول موثق من الرئيس التنفيذي.

حرج 20–25	عالٍ 15–19	متوسط 8–14	منخفض 3–7	منخفض جداً 1–2

الاحتمال ↑

5 شبه مؤكد	5 منخفض	10 متوسط	15 عالٍ	20 حرج	25 حرج
4 محتمل	4 منخفض	8 متوسط	12 متوسط	16 عالٍ	20 حرج
3 غير مرجح	3 منخفض	6 منخفض	9 متوسط	12 متوسط	15 عالٍ
2 نادر	2 منخفض جداً	4 منخفض	6 منخفض	8 متوسط	10 متوسط
1 نادر جداً	1 منخفض جداً	2 منخفض جداً	3 منخفض	4 منخفض	5 منخفض
	1 منخفض جداً	2 منخفض	3 متوسط	4 عالٍ	5 حرج

الأثر يزداد نحو اليمين ←

المصفوفة والمستويات كما وردت في الشكلين 2 و3 من NFCRM-1:2025.

لماذا 3 و4؟ مبرر كل درجة

الاحتمال 3 يتنقل الموظف يومياً بالحاسوب، وسُجلت في رُفاد سرقة حاسوب واحدة خلال 3 سنوات: «غير مرجح» قد يقع مرة كل 2 إلى 3 سنوات.

الأثر 4 تسرب بيانات حساسة لكل الموظفين بأثر كبير على الجهة: «عالٍ».

ما الذي يغير الدرجة؟

- لو سُرق حاسوبان في السنة الماضية، يرتفع الاحتمال إلى 4.
- لو كانت الملفات أسماء فقط بلا رواتب أو حسابات، ينخفض الأثر.
- الدرجة تُكتب مع مبررها في السجل، ليراجعها غيرك.

الخطر المتأصل والمتبقي: الانخفاض ليس تلقائياً

المتأصل: قبل خطة المعالجة

الاحتمال 3 × الأثر 4

12 · متوسط

المتبقي المتوقع: بعد التشفير

الاحتمال 3 × الأثر 2

6 · منخفض

بشرط أن:

- ✓ التشفير مفعّل ومُتحقق منه على كل الأجهزة المعنية، لا على بعضها.
- ✓ الجهاز محمي بكلمة مرور قوية، ومفاتيح الاسترداد محفوظة بأمان.
- ✓ لا تبقى نسخ من ملفات الرواتب خارج المجلد المقيد.

⚠ التشفير لا يمنع السرقة، فالاحتمال لا يتغير. يقلل الأثر فقط، وبشرط أن يعمل فعلاً على كل الأجهزة.

أربعة خيارات لمعالجة الخطر

التخفيف

ضوابط تقلل الاحتمال أو الأثر.

في رُفاد: تشفير حواسيب الرواتب.

التجنب

إيقاف النشاط المسبب للخطر.

في رُفاد: منع حفظ ملفات الرواتب على الأجهزة.

المشاركة

تحميل جزء من الأثر لطرف آخر.

في رُفاد: تأمين، أو عقد. المسؤولية لا تنتقل.

القبول

قرار موثق ممن يملك الصلاحية.

في رُفاد: قبول مؤقت مع موعد مراجعة.

⚠ قبول الخطر قرار داخلي. لا يلغي التزاماً نظامياً، ولا يمنح إعفاءً من جهة تنظيمية.

شهية المخاطر وحدود التحمل

شهية المخاطر

حجم الخطر الذي تقبله الجهة عموماً لتحقق أهدافها. يقرها المجلس أو صاحب الصلاحية.

> «لا نقبل مخاطر عالية على بيانات الموظفين والعملاء.»

حدود التحمل

حدود قابلة للقياس تطبق الشهية على خطر أو مؤشر محدد.

> «لا يبقى خطر عالٍ بلا خطة أكثر من 30 يوماً.» «توقف الرواتب لا يتجاوز يوم عمل.»

المستوى	القرار في رُفاد
منخفض جداً أو منخفض	يقبله مالك الخطر ويوثقه
متوسط	خطة معالجة، أو قبول موثق من الرئيس التنفيذي
عالٍ أو حرج	معالجة إلزامية، وعرض على اللجنة

الضوابط: طبيعتها ووظيفتها

الطبيعة	وقائي: يمنع	كشفي: يكتشف	تصحيحي: يعالج
إداري	سياسة الاستخدام، والتوعية	مراجعة الصلاحيات الدورية	خطة الاستجابة للحوادث
تقني	التحقق متعدد العوامل، والتشفير	تنبيهات الدخول، وسجلات الأحداث	الاستعادة من النسخ
مادي	أقفال غرفة الخوادم	كاميرات المراقبة	موقع بديل

صنّف الضابط بالبعدين معاً: «التحقق متعدد العوامل ضابط تقني وقائي».

الضابط التعويضي بديل يحقق الهدف نفسه حين يتعذر الأصلي.

مثال محلول: من هدف العمل إلى قرار الإدارة

أهداف رُفاد التي يخدمها GRC:

استمرار التوصيل: تتبع الشحنات متاح للمتاجر والمستلمين.	حماية بيانات العملاء: بيانات المستلمين لا تتسرب.	صحة الرواتب: رواتب صحيحة إلى الحسابات الصحيحة في موعدها.	الالتزام بالعقود: ما وعدت به رُفاد المتاجر والمورد.

1. هدف العمل	استمرار تتبع الشحنات، والوفاء بالتزام عقود المتاجر: إتاحة 99% شهرياً.
2. الأصل الداعم	خادم تطبيق التتبع السحابي، ويديره المورد سَنَد عن بعد.
3. الخطر	بسبب تأخر ترقيع الثغرات الحرجة في خادم مكشوف على الإنترنت، قد يُستغل فيتوقف التتبع أو تتسرب بيانات المستلمين. 4 × 4 = 16 · عالٍ.
4. الضابط	فحص شهري للثغرات، وترقيع الحرجة خلال 14 يوماً، ومهلة الترقيع بند في عقد سَنَد.
5. المالك	مالك الخطر: م. سلمان، مدير تقنية المعلومات. المنفذ: سَنَد تحت إشرافه.
6. المؤشر	KRI: الثغرات الحرجة المفتوحة أكثر من 14 يوماً. في 30 سبتمبر 2026: 3. الحد: صفر.
7. القرار المطلوب	اعتماد كلفة ترقيع عاجل الآن، وإضافة المهلة إلى العقد عند تجديده. الخطر عالٍ، فلا يُقبل.

صياغة الأثر بلغة الأعمال

صِف الأثر بواحد أو أكثر من:

توقف خدمة · تأخير عمليات · تسرب بيانات · تكلفة · التزام تعاقدي

بلغة تقنية	بلغة الأعمال	نوع الأثر
ثغرة حرجة غير مرقعة في خادم التتبع.	قد يتوقف تتبع الشحنات لكل المتاجر، فتتأخر التسليمات وتكثر الشكاوى.	توقف خدمة
حسابان لمغادرين نشطان في نظام الرواتب.	شخصان خارج الشركة قد يطلعان على رواتب الموظفين وحساباتهم البنكية.	تسرب بيانات
النسخ يومي، والحد المقبول لفقد البيانات 4 ساعات.	قد نفقد يوم عمل من تعديلات الرواتب، فيتأخر الصرف أو يخطئ.	تأخير عمليات
عقد سَنَد بلا بند للإبلاغ عن الحوادث.	قد لا نعلم بتسرب في الوقت، فنتأخر في إبلاغ المتاجر والجهة المختصة.	التزام تعاقدي

المدير لا يقرر بناءً على «ثغرة حرجة»، بل على ما تعنيه لخدمته وعملائه وتكلفته والتزاماته.

تمرين: من هدف «صحة الرواتب» إلى القرار

ما وجدته في رُفاد

- هدف رُفاد: رواتب صحيحة تُصرف إلى الحسابات الصحيحة في موعدها، لنحو 200 موظف.
- في نظام الرواتب يستطيع موظفان تعديل الحساب البنكي للموظف واعتماد المسير كليهما.
- لا توجد موافقة ثانية على تغيير الحساب البنكي، ولا تقرير بالتغييرات.
- مالكة النظام: أ. منى، مديرة الموارد البشرية. والمدير المالي أ. فهد مسؤول عن الصرف.

أكمل السلسلة في الكراسة:

1. هدف العمل	2. الأصل الداعم	3. الخطر	4. الضابط	5. المالك	6. المؤشر	7. القرار المطلوب

ثم صِف الأثر بلغة الأعمال، واذكر نوعه. 12 دقيقة.

الإجابة: السلسلة كاملة لهدف «صحة الرواتب»

1. هدف العمل	صرف رواتب صحيحة إلى الحسابات الصحيحة في موعدها.
2. الأصل الداعم	نظام الموارد البشرية والرواتب، وبيانات الحسابات البنكية فيه.
3. الخطر	بسبب جمع موظف واحد لتعديل الحساب البنكي واعتماد المسير، قد يُحوَّل راتب إلى حساب غير صحيح دون اكتشاف، مما يسبب خسارة مالية وتأخر راتب موظف ومساءلة داخلية.
4. الضابط	فصل المهام: من يعدّل لا يعتمد، وموافقة ثانية على تغيير الحساب البنكي، وتقرير شهري بالتغييرات يراجعه المدير المالي.
5. المالك	مالكة الخطر والنظام: أ. منى. ومراجعة التقرير الشهري: أ. فهد.
6. المؤشر	عدد تغييرات الحسابات البنكية بلا موافقة ثانية في الشهر. الحد المقبول: صفر.
7. القرار المطلوب	اعتماد إعادة توزيع الأدوار في الموارد البشرية، وقبول تأخير قصير في التعديلات بسبب الموافقة الثانية.

الأثر: تكلفة مالية، وتأخير عمليات الصرف، ومساءلة. ومقبول أيضاً أن تختار KCI مثل «نسبة التغييرات بموافقة ثانية»، إن كتبت غرضه.

سجل المخاطر: صف مكتمل من رُفاد

سجل المخاطر · رُفاد — نموذج تعليمي · بيانات افتراضية

fx بسبب حفظ ملفات تصدير الرواتب على حاسوب محمول غير مشفر، قد يؤدي فقدانه أو سرقته إلى اطلاع غير مصرح به على رواتب 200 موظف وحساباتهم البنكية، مما يضر الموظفين ويعرض رُفاد لمخالفة نظام حماية البيانات الشخصية ولضرر في سمعتها.

	A	B	C	D	E	F	G	H	I	J	K	L	M
1	**الرقم**	**الأصل**	**وصف الخطر**	**الضوابط الحالية**	**الاحتمال**	**الأثر**	**المستوى**	**مالك الخطر**	**المعالجة**	**مالك الإجراء**	**الموعد**	**المتبقي المتوقع**	**المتابعة**
2	R-07	حاسوب أخصائي...	بسبب حفظ ملفات...	كلمة مرور...	3	4	12 · متوسط	مديرة الموارد...	التخفيف: تشفير...	مدير تقنية...	30 يوماً	6 · منخفض	تتحقق GRC...
3													
4													

صف واحد مكتمل للخطر R-07. الخلية المحددة C2 يظهر نصها كاملاً في شريط الصيغة. في الشرائح الثلاث التالية نكبّر أعمدته بالترتيب.

السجل (1 من 3): الأصل ووصف الخطر

	A	B	C
1	**الرقم**	**الأصل**	**وصف الخطر**
2	R-07	حاسوب أخصائي الرواتب وملفات تصدير الرواتب	بسبب حفظ ملفات تصدير الرواتب على حاسوب محمول غير مشفر، قد يؤدي فقدانه أو سرقته إلى اطلاع غير مصرح به على رواتب 200 موظف وحساباتهم البنكية، مما يضر الموظفين ويعرض رُفاد لمخالفة نظام حماية البيانات الشخصية ولضرر في سمعتها.
3			

B الأصل
ما نحميه: الحاسوب والملفات عليه.

C السبب: «بسبب...»
الثغرة: ملفات على قرص غير مشفر.

C الحدث: «قد...»
فقد الجهاز أو سرقته، ثم اطلاع غير مصرح به.

C الأثر: «مما...»
ضرر للموظفين، ومخالفة نظامية، وضرر في السمعة.

السجل (2 من 3): الضوابط والتقييم والمالك

	D	E	F	G	H
1	**الضوابط الحالية**	**الاحتمال**	**الأثر**	**المستوى**	**مالك الخطر**
2	كلمة مرور لحساب الجهاز، وسياسة الاستخدام المقبول. لا تشفير للقرص.	3 · غير مرجح	4 · عالٍ	12 · متوسط	مديرة الموارد البشرية
3					

D الضوابط الحالية
ما يوجد فعلاً اليوم، حتى الضعيف منه.

E الاحتمال 3
سرقة واحدة خلال 3 سنوات: «غير مرجح».

F الأثر 4
بيانات حساسة لكل الموظفين: «عالٍ».

G المستوى
3 × 4 = 12: «متوسط» في المصفوفة.

H مالك الخطر
مديرة الموارد البشرية، لا GRC.

السجل (3 من 3): المعالجة والمتبقي والمتابعة

	I	J	K	L	M
1	**المعالجة**	**مالك الإجراء**	**الموعد**	**المتبقي المتوقع**	**المتابعة**
2	التخفيف: تشفير القرص الكامل لحواسيب الموارد البشرية والمالية، وحفظ ملفات الرواتب في مجلد سحابي مقيد بدل الجهاز.	مدير تقنية المعلومات	30 يوماً	3 × 2 = 6 · منخفض	تتحقق GRC من تقرير التشفير بعد 30 يوماً، وتحدّث السجل.
3					

I المعالجة
التخفيف: تشفير الأقراص، ومجلد سحابي مقيد.

J مالك الإجراء والموعد
مدير تقنية المعلومات، خلال 30 يوماً.

L المتبقي المتوقع
6، منخفض، بشرط أن يعمل التشفير على كل الأجهزة.

M المتابعة
GRC تتحقق من تقرير التشفير وتحدّث السجل.

دورك: حساب المورد المشترك

ما وجدته في رُفاد

- سَنَد يدير خادم تطبيق التتبع عن بعد بأداة دعم مكشوفة على الإنترنت.
- حساب إداري مشترك واحد «sanad-admin» يستخدمه 5 فنيين.
- كلمة المرور لم تتغير منذ 2023، ولا يوجد تحقق متعدد العوامل.
- الوصول مفتوح على مدار الساعة دون طلب أو موافقة.
- الأداة تحفظ سجلات الجلسات 30 يوماً، ولا أحد يراجعها.
- العقد فيه بند سرية فقط: لا إبلاغ عن الحوادث ولا التزام بسياسات رُفاد.
- الخادم يحفظ أسماء المستلمين وهواتفهم وعناوينهم: نحو 50 ألف مستلم شهرياً.

دورك: المطلوب والنموذج

1. اكتب الخطر بصيغة: بسبب... قد... مما يؤدي إلى...
2. اذكر الضوابط الحالية.
3. قدّر الاحتمال والأثر بأوصاف المصفوفة، وبرر كلاً منهما، ثم احسب المستوى.
4. اقترح معالجة: خيار، وثلاثة إجراءات، لكل منها مالك وموعد.
5. قدّر الخطر المتبقي المتوقع واذكر افتراضاتك.

وصف الخطر

بسبب... قد... مما يؤدي إلى...

الاحتمال والأثر

... × ... = ...، والمبرر:

المعالجة

الخيار، والإجراءات، والمالك، والموعد

استخدم المصفوفة في الشريحة 64. النموذج كاملاً في الكراسة. 20 دقيقة.

الإجابة: الوصف والتقييم

بسبب استخدام حساب إداري مشترك لمورد الدعم عبر أداة وصول عن بعد مكشوفة على الإنترنت بلا تحقق متعدد العوامل، قد يستخدم مهاجم كلمة مرور مسربة أو مخمّنة للدخول إلى خادم تطبيق التتبع، مما يؤدي إلى تسرب البيانات الشخصية للمستلمين أو تعطيل خدمة التتبع.

الضوابط الحالية كلمة مرور قديمة، وبند سرية في العقد، وسجلات جلسات 30 يوماً بلا مراجعة.

الاحتمال 4 «محتمل»: الاستغلال سهل متى عُرفت كلمة المرور، وهي مشتركة بين 5 أشخاص ولم تتغير منذ سنوات. لم نختر 5 لأن المهاجم يحتاج أولاً إلى كلمة المرور، ولا توجد ثغرة منشورة تتجاوزها.

الأثر 4 «عالٍ»: تسرب بيانات شخصية لعشرات الآلاف مع احتمال توقف الخدمة، بأثر كبير على رُفاد. لم نختر 5 لأن الأثر لا يمتد إلى المستوى الوطني.

المستوى 4 × 4 = 16 · عالٍ: معالجة إلزامية وعرض على اللجنة.

الإجابة: المعالجة

الخيار التخفيف، وعلى الخطر مالك واحد: مدير تقنية المعلومات.

الإجراء	المالك	الموعد
حسابات فردية لكل فني وإلغاء الحساب المشترك	مدير تقنية المعلومات	14 يوماً
تفعيل التحقق متعدد العوامل على أداة الوصول (ECC 2-2-3-2)	مدير تقنية المعلومات	14 يوماً
إيقاف الوصول الدائم: وصول عند الطلب بموافقة	مدير تقنية المعلومات	30 يوماً
مراجعة أسبوعية لسجلات الجلسات	مدير تقنية المعلومات	30 يوماً
إضافة بنود ECC 4-1-2 عند تجديد العقد	المدير المالي	عند التجديد

طلب التمرين ثلاثة إجراءات. أهمها: الحسابات الفردية، والتحقق متعدد العوامل، والوصول عند الطلب.

الإجابة: الخطر المتبقي والقرار

قبل المعالجة

4 × 4 = 16

عالٍ

←

المتبقي المتوقع

2 × 4 = 8

متوسط

لماذا بعد الإجراءات يصبح الاحتمال «نادراً» (2) لأن كلمة المرور وحدها لا تكفي. الأثر يبقى «عالياً» (4) لأن البيانات نفسها ما زالت على الخادم. النتيجة 8: «متوسط».

القرار المتوسط يحتاج قراراً: قبول موثق من الرئيس التنفيذي، أو معالجة إضافية مثل حصر الوصول بعناوين المورد المعتمدة.

التطبيق 2: أخطاء شائعة

لماذا الإجابة النموذجية أفضل

- «لا يوجد تحقق متعدد العوامل» ثغرة، وليست خطراً كاملاً. الخطر يربط الثغرة بحدث وأثر.
- كل درجة لها مبرر مأخوذ من أوصاف المصفوفة، لا من الانطباع.
- التحقق متعدد العوامل يقلل الاحتمال ولا يغير الأثر.
- المعالجة عند الخط الأول، وGRC يتابع، والمورد لا يملك الخطر.

أخطاء شائعة

- كتابة الثغرة وحدها خطراً: «لا يوجد MFA».
- درجات بلا تبرير، أو خلط الاحتمال بالأثر.
- افتراض أن الخطر يصبح «منخفضاً جداً» تلقائياً بعد أي ضابط.
- اختيار «النقل إلى المورد» معالجة؛ المسؤولية لا تنتقل.
- إجراءات بلا مالك أو موعد، أو مالكها GRC.

مخاطر الأطراف الخارجية: من التقييم إلى الإنهاء

1
قبل التعاقد
تقييم المخاطر: ما الخدمة، وما البيانات والوصول؟ (ECC 4-1-3-1)

سَنَد: لم يُقيَّم سَنَد قبل توقيع العقد.

2
العقد
السرية وحذف البيانات، والإبلاغ عن الحوادث، والالتزام بالسياسات (ECC 4-1-2).

سَنَد: بند سرية فقط.

3
الوصول
حسابات فردية بأقل صلاحية وMFA، وسجلات تُراجع.

سَنَد: حساب مشترك sanad-admin لخمسة فنيين.

4
المتابعة
مراجعة دورية للأداء والالتزام وتحديث التقييم (ECC 4-1-4).

سَنَد: لا مراجعة دورية.

5
الإنهاء
إلغاء الصلاحيات، وإعادة البيانات وحذفها الآمن.

سَنَد: لا إجراء مكتوب للإنهاء.

⚠ قدرة الجهة على فرض الشروط تضعف بعد التوقيع: التقييم والعقد أهم مرحلتين.

استمرارية الأعمال: RTO وRPO

تحليل أثر الأعمال (BIA) يحدد أهم الخدمات، وكم تتحمل الجهة توقفها.



> نظام الرواتب في رُفاد: RTO يوم عمل واحد، وRPO أربع ساعات. النسخة اليومية لا تكفي، فهذه فجوة تُكتب ملاحظة.

BIA وBCP وDRP والحوادث: أين يقف GRC؟

BIA
تحليل أثر الأعمال

ما أهم الخدمات؟ وكم تتحمل الجهة توقفها؟ ومنه RTO وRPO.

في رُفاد: الرواتب: RTO يوم عمل، وRPO أربع ساعات.

BCP
خطة استمرارية الأعمال

كيف تستمر الخدمة المهمة أثناء التوقف، ومن يقرر؟

في رُفاد: إجراء بديل معتمد لصرف الرواتب إن تعذر النظام.

DRP
خطة التعافي من الكوارث

كيف تُستعاد الأنظمة والبيانات تقنياً، وبأي ترتيب؟

في رُفاد: استعادة بيانات الرواتب من النسخ.

IR
الاستجابة للحوادث

اكتشاف الحادثة واحتواؤها والتعافي منها، والإبلاغ عنها.

في رُفاد: تسرب من خادم التتبع: من يُبلَّغ، ومتى.

ما يفعله GRC

- ✓ يتأكد أن الخطط موجودة ومعتمدة ومختبرة.
- ✓ يربط نتائج الاختبار والحوادث بسجل المخاطر والملاحظات.

ما لا يفعله

- ⚠ لا يقود الاستجابة الفنية للحادثة.
- ⚠ لا يكتب خطة التعافي التقنية بدل أصحابها.

حماية البيانات الشخصية: الأساسيات

في المملكة: نظام حماية البيانات الشخصية (PDPL)، والجهة المختصة سدايا. دخل حيز النفاذ في 14 سبتمبر 2023.

- ✓ أساس نظامي لكل معالجة، وغرض محدد، وأقل قدر من البيانات.
- ✓ حقوق لصاحب البيانات، منها العلم والوصول والتصحيح والإتلاف.
- ✓ سجل لأنشطة المعالجة، وتقييم أثر للمعالجات عالية المخاطر.
- ✓ إبلاغ الجهة المختصة عن حوادث التسرب خلال المدة المحددة في اللوائح.

في رُفاد: بيانات الموظفين في نظام الرواتب، وبيانات المستلمين في تطبيق التتبع، كلاهما بيانات شخصية.

الجزء الثالث

الامتثال

هل نلتزم بما يجب، وكيف نثبت ذلك؟

المتطلب والضابط والدليل والنتيجة
النطاق والانطباق
التوثيق والتطبيق والتشغيل
الأدلة وكفايتها
العينات

تقييم ضابط كامل
التطبيق 3
الملاحظة وخطة التصحيح
التطبيق 4

المتطلب والضابط والدليل ونتيجة التقييم

المتطلب

ماذا يجب؟

ECC 2-2-3-5: مراجعة دورية للصلاحيات.

←

الضابط

كيف تلتزم الجهة؟

مراجعة ربع سنوية لنظام الرواتب بمعيار معتمد.

←

الدليل

ما الذي يثبت؟

ملف المراجعة، والاعتماد، وتذاكر الإزالة.

←

نتيجة التقييم

إلى أي حد؟

مطبق، أو جزئياً، أو غير مطبق، أو لا ينطبق.

المتطلب واحد، والضابط اختيار الجهة لتحقيقه. لذلك قد تحقق جهتان المتطلب نفسه بضابطين مختلفين.

النطاق والانطباق قبل طلب الأدلة

قبل أن تطلب أي دليل، اتفق مكتوباً على النطاق. مثال: تقييم رُفاد الداخلي للنصف الأول من 2026.

السؤال	الإجابة في رُفاد
ما المتطلبات المنطبقة؟	ضوابط الهويات 2-2-3 كلها، و5-9-1.
ما الأنظمة ضمن النطاق؟	نظام الرواتب، والبريد، وVPN، وتطبيق التتبع.
ما الفترة؟	1 يناير إلى 30 يونيو 2026.
من مالك كل ضابط؟	سلمان للتقنية، ومنى لنظام الرواتب.
ما المستثنى ولماذا؟	خادم تجريبي معزول بلا بيانات حقيقية: «لا ينطبق» بمبرر موثق.

⚠ دليل خارج الفترة أو خارج النطاق لا يُحتسب، مهما كان جيداً.

موثق، ومطبق، ويعمل باستمرار

موثق

هل المتطلب مكتوب ومعتمد؟

دليله: سياسة أو معيار معتمد.

معيار الوصول عن بعد · فبراير 2026

«التحقق متعدد العوامل إلزامي لكل مستخدمي VPN.»

مطبق

هل الإعداد أو الإجراء قائم؟

دليله: تصدير إعداد من النظام بتاريخه.

VPN-Users-MFA

كلمة المرور + رمز · لقطة 5 يوليو

يعمل باستمرار

هل عمل طوال الفترة ولكل النطاق؟

دليله: سجلات وملفات تغطي الفترة كاملة.

03-12 كلمة المرور + رمز

04-02 كلمة المرور + رمز

06-24 كلمة المرور + رمز

سجل يغطي الفترة كلها

سياسة موجودة لا تثبت إعداداً، وإعداد اليوم لا يثبت ما حدث في الأشهر الماضية.

الأدلة: الأنواع، وكيف تحكم على كفايتها

أنواع الأدلة

- وثائق معتمدة: سياسات، ومحاضر
- تصدير من النظام: إعدادات وقوائم
- سجلات وتقارير: ما حدث فعلاً
- مقابلات وملاحظة مباشرة
- إعادة التنفيذ: تجرب الضابط بنفسك

هل يكفي الدليل؟ اسأل:

- مرتبط: هل يجيب عن هدف الفحص؟
- موثوق: ما مصدره؟ من النظام أم نسخة معدّلة؟
- كافٍ: هل يغطي الفترة والمجتمع؟
- مؤرخ: هل يقع داخل الفترة؟

لا يوجد ترتيب ثابت لقوة الأدلة. المقابلة تساعدك على الفهم، والسجلات قد تكون ناقصة. القيمة تعتمد على هدف الفحص ومصدر الدليل وتغطيته.

المجتمع والعينة وحدود الاستنتاج

المجتمع والعينة

- ✓ المجتمع: كل الحالات في الفترة، مثل 41 حساب VPN.
- ✓ إن أمكن تصديره كاملاً، افحصه كاملاً.
- ✓ العينة: جزء مختار بطريقة معروفة، عشوائياً أو بمعيار مبرر.

حدود الاستنتاج

- ⚠ نتيجة العينة تخص ما فحصته، والتعميم يحتاج مبرراً.
- ⚠ استثناءان من حساب واحد لا يعنيان أن كل الحسابات ضعيفة.
- ⚠ السبب الجذري يُتحقق منه، ولا يُستنتج من بريد أو انطباع.

تقييم ضابط كامل: ثمانية عناصر

1 المتطلب
النص ورقمه

2 التفسير
ماذا يعني في الجهة

3 المالك
من يطبق الضابط

4 الأدلة
ما طلبته وما وصل

5 طريقة الفحص
كيف اختبرت كل دليل

6 النتيجة
من مقياس محدد

7 الملاحظة
إن وُجدت فجوة

8 خطة التصحيح
إجراء، ومالك، وموعد

في مثال التطبيق 3 نعبئ هذه العناصر لضابط من رُفاد، ثم تعبئها أنت لضابط آخر.

مقياس نتيجة التقييم

النتيجة	المعنى
مطبق	المتطلب موثق ومطبق، ويعمل باستمرار طوال فترة التقييم.
مطبق جزئياً	جزء من المتطلب مطبق، أو طُبق في جزء من الفترة فقط.
غير مطبق	لا دليل على التطبيق، أو الأدلة تنفي التطبيق.
لا ينطبق	المتطلب خارج النطاق، بمبرر موثق.

⚠ المقاييس تختلف بين الجهات والجهات المنظمة. استخدم دائماً مقياس الجهة التي تقيّمها.

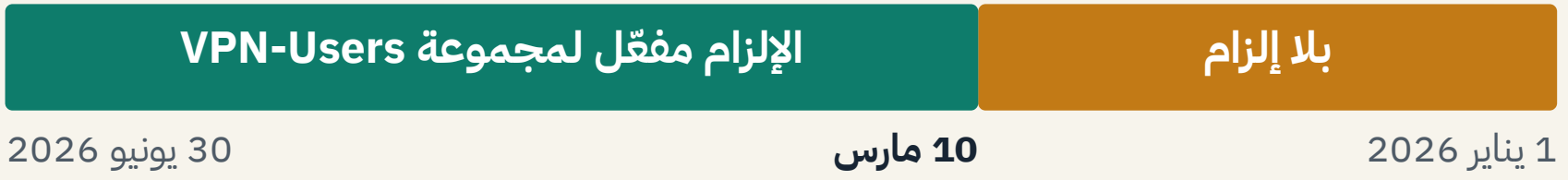
مثال محلول: المتطلب والنطاق والفترة

المتطلب ECC 2-2-3-2: التحقق متعدد العوامل للدخول عن بعد وللحسابات ذات الصلاحيات الهامة.

النطاق والفترة دخول الموظفين عن بعد عبر الشبكة الافتراضية VPN. الفترة: 1 يناير إلى 30 يونيو 2026. الحسابات ذات الصلاحيات الهامة تُقيّم منفصلة.

المالك مدير تقنية المعلومات

فترة التقييم



حددنا النطاق والفترة قبل طلب أي دليل. أي دليل خارج الفترة يحتاج دليلاً يغطيها.

مثال محلول: الأدلة المستلمة

الدليل	ما وصل
د1	معيار الوصول عن بعد، معتمد فبراير 2026: التحقق متعدد العوامل إلزامي لكل مستخدمي VPN.
د2	لقطة إعداد من بوابة VPN بتاريخ 5 يوليو 2026: التحقق إلزامي لمجموعة «VPN-Users».
د3	سجل تغييرات الإعداد: فُعّل الإلزام لمجموعة «VPN-Users» في 10 مارس 2026، وفي اليوم نفسه أُنشئت سياسة «VPN-Legacy» بكلمة المرور فقط لثلاثة حسابات.
د4	قائمتان بالمعرّفات: أعضاء «VPN-Users» (38 حساباً)، والحسابات التي اتصلت خلال الفترة (41 حساباً).
د5	عينة 25 اتصالاً بعد 10 مارس: 23 بعامل ثانٍ، و2 بكلمة المرور فقط، كلاهما من حساب «test».
د6	مستخرج من سجل الاتصالات لكل اتصالات الحسابات الثلاثة خارج المجموعة بعد 10 مارس: 29 اتصالاً، كلها بكلمة المرور فقط.

قبل أن تنتقل: ماذا يثبت كل دليل؟ وهل تكفي لقطة 5 يوليو؟

الدليل د2: لقطة إعداد التحقق

بوابة الوصول عن بعد — نموذج تعليمي · بيانات افتراضية

سياسات التحقق · VPN-Users-MFA

اسم السياسة	VPN-Users-MFA
المجموعة	VPN-Users · 38 عضواً
طريقة التحقق	كلمة المرور + رمز من تطبيق التحقق
الحالة	مفعّلة
آخر تعديل	10 مارس 2026

تاريخ اللقطة: 5 يوليو 2026

ما الذي نراه؟

سياسة MFA مفعّلة لمجموعة VPN-Users (38 عضواً)، في لقطة 5 يوليو.

ماذا يثبت؟

الإلزام مضبوط لهذه المجموعة يوم اللقطة فقط.

ماذا لا يثبت؟

ما كان قبل 5 يوليو، ولا من يتصل من خارج المجموعة.

ما المطلوب إضافةً؟

سجل التغييرات، وقائمة كل السياسات.

الدليل د3: سجل التغييرات

سجل تغييرات بوابة VPN · المنفّذ في كل السطور: it-admin01

نموذج تعليمي · بيانات افتراضية

الوقت	التغيير	تعليق
2026-02-18 14:10	تجديد شهادة البوابة	
2026-03-10 09:42	VPN-Users-MFA: التحقق متعدد العوامل = إلزامي	
2026-03-10 10:05	إنشاء سياسة VPN-Legacy: كلمة المرور فقط	مؤقت
2026-03-10 10:07	إضافة test وext-consult01 وit-support02 إلى VPN-Legacy	مؤقت

ما الذي نراه؟

10 مارس 09:42 فُعّل الإلزام. وبعده بدقائق: سياسة VPN-Legacy بكلمة المرور فقط لثلاثة حسابات، «مؤقت».

ماذا يثبت؟

تاريخ التفعيل، واستثناء لثلاثة حسابات منذ اليوم نفسه.

ماذا لا يثبت؟

أن الحسابات اتصلت فعلاً، ولا أن الاستثناء معتمد.

ما المطلوب إضافةً؟

سجل اتصالاتها، وأي موافقة على الاستثناء.

الدليل د4: مطابقة المعرّفات

مطابقة المعرّفات · اتصالات VPN في الفترة — نموذج تعليمي · بيانات افتراضية

	A	B	C	D
1	**المعرّف**	**في سجل الاتصالات**	**عضو في VPN-Users**	**النتيجة**
2	s.almutairi	نعم	نعم	مطابق
3	n.alzahrani	نعم	نعم	مطابق
4	… 36 حساباً آخر	نعم	نعم	مطابق
5	test	نعم	لا	خارج المجموعة
6	ext-consult01	نعم	لا	خارج المجموعة
7	it-support02	نعم	لا	خارج المجموعة

41 حساباً اتصلت · 38 منها أعضاء في المجموعة · 3 خارجها

ما الذي نراه؟

كل معرّف اتصل في الفترة مقابل أعضاء المجموعة: 38 مطابقة، و3 خارجها.

ماذا يثبت؟

من اتصل من خارج مجموعة التحقق، بالاسم.

ماذا لا يثبت؟

طريقة التحقق في اتصالاتهم. وفرق 41 − 38 وحده لا يثبت شيئاً.

ما المطلوب إضافةً؟

سجل اتصالات الحسابات الثلاثة بعد 10 مارس.

الدليل د6: سجل الاتصالات

سجل الاتصالات · مستخرج بعد 10 مارس 2026 — نموذج تعليمي · بيانات افتراضية

الوقت	الحساب	طريقة التحقق	النتيجة
2026-03-12 08:14	test	كلمة المرور فقط	ناجح
2026-03-12 08:20	s.almutairi	كلمة المرور + رمز	ناجح
2026-03-19 21:40	it-support02	كلمة المرور فقط	ناجح
2026-04-02 09:05	ext-consult01	كلمة المرور فقط	ناجح
2026-04-27 16:22	ext-consult01	كلمة المرور فقط	ناجح
2026-06-24 22:08	it-support02	كلمة المرور فقط	ناجح

29 اتصالاً بعد 10 مارس، كلها بكلمة المرور فقط:

test: 9 · ext-consult01: 6 · it-support02: 14

العينة د5 (25 اتصالاً) لم تُظهر إلا حساب test.

ما الذي نراه؟

29 اتصالاً للحسابات الثلاثة بعد 10 مارس، كلها بكلمة المرور فقط.

ماذا يثبت؟

ثلاثة حسابات اتصلت دون عامل ثانٍ بعد التفعيل.

ماذا لا يثبت؟

سبب الاستثناء، ولا من وافق عليه.

ما المطلوب إضافةً؟

مقابلة فريق تقنية المعلومات، وأي وثيقة موافقة.

مثال محلول: الفحص والنتيجة

سؤال الفحص	ما وجدناه
هل المتطلب موثق؟	نعم: د1 يغطي المتطلب.
هل الإعداد مطبق، ومنذ متى؟	نعم لمجموعة «VPN-Users» منذ 10 مارس (د3). اللقطة د2 بعد الفترة، فلا تكفي وحدها.
هل يشمل كل من يتصل؟	لا: مطابقة المعرّفات (د4) تحدد 3 حسابات متصلة خارج المجموعة، وسجلها (د6) بكلمة المرور فقط.
هل يعمل طوال الفترة؟	لا: لا إلزام قبل 10 مارس (د3).

النتيجة

مطبق جزئياً

المتطلب موثق ومطبق على المجموعة الرئيسية منذ 10 مارس، لكنه لم يعمل في أول الفترة، وثلاثة حسابات حددتها مطابقة المعرّفات تتصل بكلمة المرور فقط.

العينة (د5) كشفت حساباً واحداً من الثلاثة فقط. مطابقة المعرّفات (د4) مع سجل الاتصالات (د6) هي التي حددتها بدقة، ولا يكفي فرق العدد بين 41 و38 وحده: قد يكون بعض الأعضاء لم يتصلوا، وبعض المتصلين من خارج المجموعة.

دورك: مراجعة صلاحيات نظام الرواتب

المتطلب ECC 2-2-3-5: المراجعة الدورية لهويات الدخول والصلاحيات.

النطاق والفترة نظام الموارد البشرية والرواتب. الفترة: 1 يناير إلى 30 يونيو 2026 (ربعان).

المعيار المعتمد معيار التحكم بالوصول، معتمد 15 يناير 2026: مراجعة كل 3 أشهر، واعتماد خلال 10 أيام عمل، وإزالة خلال 5 أيام عمل.

المسطرة التي ستقيس بها:

كل 3 أشهر
تكرار المراجعة

10 أيام عمل
من التصدير إلى الاعتماد

5 أيام عمل
من الاعتماد إلى الإزالة

هذا الضابط هو الذي كتبنا بنده في التطبيق 1. الآن نفحص: هل التزمت به رُفاد فعلاً؟

دورك: الأدلة المستلمة

الدليل	ما وصل
د1	معيار التحكم بالوصول المعتمد في 15 يناير 2026.
د2	ملف مراجعة الربع الأول: تصدير 29 مارس، 214 حساباً، اعتمدته مالكة النظام في 8 أبريل، و12 حساباً للإزالة.
د3	تذاكر الإزالة: 9 حسابات أزيلت حتى 12 أبريل، و3 أزيلت في 20 مايو.
د4	لا ملف لمراجعة الربع الثاني. بريد من تقنية المعلومات: «تأجلت بسبب ترحيل النظام إلى إصدار جديد في يونيو».
د5	تصدير الحسابات النشطة في 2 يوليو: 221 حساباً، منها حسابان لموظفين غادروا في مايو.
د6	مقابلة مع مالكة النظام: «نراجع الصلاحيات عندما يطلب المدير».

انتبه للتواريخ ولمهلة كل خطوة في المعيار.

دليلك د2: ملف مراجعة الربع الأول

مراجعة صلاحيات نظام الرواتب · الربع الأول 2026 · مقتطف 6 من 214 — نموذج تعليمي · بيانات افتراضية

المعرّف	الدور في النظام	قرار المدير	ملاحظة
hr.n.alharbi	مسؤول الرواتب	إبقاء	
fin.m.salem	عرض التقارير المالية	إبقاء	
hr.s.dosari	تعديل الرواتب	إزالة	انتقل إلى العمليات في فبراير
it.f.otaibi	مدير النظام	إبقاء	
ops.r.shahri	عرض بيانات الموظفين	إزالة	لا تحتاجها في عملها الحالي
hr.temp02	إدخال الحضور	إزالة	انتهى العقد في مارس

تاريخ التصدير: 29 مارس 2026 عدد الحسابات: 214 للإزالة: 12

الاعتماد: أ. منى، مالكة النظام · 8 أبريل 2026

ما الذي نراه؟

مقتطف من ملف المراجعة: قرار المدير لكل حساب، وبيانات التصدير والاعتماد.

اكتب في الكراسة: ماذا يثبت؟ ماذا لا يثبت؟ ما المطلوب إضافةً؟

دليلك د3: تذكرة إزالة

REQ-2026-0418 مغلقة — نموذج تعليمي · بيانات افتراضية

الطلب	إزالة صلاحية «تعديل الرواتب» من hr.s.dosari
المصدر	مراجعة الربع الأول المعتمدة
المنفّذ	تقنية المعلومات
فُتح	8 أبريل 2026
أُغلق	20 مايو 2026
ملاحظة الإغلاق	تمت الإزالة.

ما الذي نراه؟

تذكرة إزالة صلاحية واحدة، بتاريخ فتح وتاريخ إغلاق.

اكتب في الكراسة: ماذا يثبت؟ ماذا لا يثبت؟ ما المطلوب إضافةً؟

دليلك د5: الحسابات النشطة والمغادرون

تصدير الحسابات النشطة · 2 يوليو 2026 · مقتطف 5 من 221 — نموذج تعليمي · بيانات افتراضية

	A	B	C	D	E
1	**المعرّف**	**الاسم**	**الدور**	**الحالة**	**آخر دخول**
2	hr.n.alharbi	نوال الحربي	مسؤول الرواتب	نشط	1 يوليو 2026
3	hr.a.ghamdi	أمل الغامدي	تعديل الرواتب	نشط	28 يونيو 2026
4	fin.y.qahtani	ياسر القحطاني	عرض التقارير المالية	نشط	9 مايو 2026
5	hr.l.shammari	لمى الشمري	إدخال الحضور	نشط	21 مايو 2026
6	it.f.otaibi	فيصل العتيبي	مدير النظام	نشط	2 يوليو 2026

ما الذي نراه؟

تصدير الحسابات النشطة في 2 يوليو، وقائمة المغادرين في مايو.

اكتب في الكراسة: ماذا يثبت؟ ماذا لا يثبت؟ ما المطلوب إضافةً؟

الموارد البشرية · المغادرون في مايو 2026 — نموذج تعليمي · بيانات افتراضية

الموظف	آخر يوم عمل
عبدالله الزهراني	7 مايو 2026
ياسر القحطاني	14 مايو 2026
لمى الشمري	28 مايو 2026

دورك: المطلوب والنموذج

لكل دليل: ماذا يثبت؟ ثم النتيجة ومبررها، وما ستطلبه قبل الإغلاق. 20 دقيقة.

الدليل	ماذا يثبت؟
د1	
د2	
د3	
د4	
د5	
د6	

النتيجة

مطبق / جزئياً / غير مطبق / لا ينطبق

المبرر

ثلاث جمل...

أدلة إضافية

ماذا ستطلب؟

الإجابة: ماذا يثبت كل دليل؟

الدليل	ماذا يثبت
د1	التوثيق: المتطلب موثق ومعتمد.
د2	التطبيق: المراجعة نُفذت واعتُمدت في موعدها للربع الأول.
د3	الاستمرار: 3 إزالات متأخرة عن مهلة 5 أيام عمل.
د4	الاستمرار: الربع الثاني لم يُنفذ. السبب ادعاء لم نتحقق منه بعد.
د5	نتيجة فعلية: صلاحيات غير مبررة بقيت نشطة.
د6	لا تثبت شيئاً وحدها، لكنها تكشف فجوة وعي بالمعيار.

الإجابة: د2 بالأسئلة الأربعة

مراجعة صلاحيات نظام الرواتب · الربع الأول 2026 · مقتطف 6 من 214 نموذج تعليمي · بيانات افتراضية

المعرّف	الدور في النظام	قرار المدير	ملاحظة
hr.n.alharbi	مسؤول الرواتب	إبقاء	
fin.m.salem	عرض التقارير المالية	إبقاء	
hr.s.dosari	تعديل الرواتب	إزالة	انتقل إلى العمليات في فبراير
it.f.otaibi	مدير النظام	إبقاء	
ops.r.shahri	عرض بيانات الموظفين	إزالة	لا تحتاجها في عملها الحالي
hr.temp02	إدخال الحضور	إزالة	انتهى العقد في مارس

تاريخ التصدير: 29 مارس 2026 عدد الحسابات: 214 للإزالة: 12

الاعتماد: أ. منى، مالكة النظام · 8 أبريل 2026

ما الذي نراه؟

قرار المدير لكل حساب، و12 للإزالة من 214، واعتماد مالكة النظام في 8 أبريل.

ماذا يثبت؟

نُفذت المراجعة واعتُمدت في موعدها: 8 أيام عمل من التصدير، والمهلة 10.

ماذا لا يثبت؟

أن الإزالات نُفذت. قرار الإزالة ليس إزالة.

ما المطلوب إضافةً؟

تذاكر الإزالة.

الإجابة: د3 بالأسئلة الأربعة

REQ-2026-0418 مغلقة — نموذج تعليمي · بيانات افتراضية

الطلب	إزالة صلاحية «تعديل الرواتب» من hr.s.dosari
المصدر	مراجعة الربع الأول المعتمدة
المنفّذ	تقنية المعلومات
فُتح	8 أبريل 2026
أُغلق	20 مايو 2026
ملاحظة الإغلاق	تمت الإزالة.

ما الذي نراه؟

طلب إزالة «تعديل الرواتب» من hr.s.dosari: فُتح 8 أبريل، وأُغلق 20 مايو.

ماذا يثبت؟

نُفذت الإزالة بعد نحو 6 أسابيع، والمهلة تنتهي 15 أبريل.

ماذا لا يثبت؟

سبب التأخير. ملاحظة الإغلاق لا تذكره.

ما المطلوب إضافةً؟

سبب تأخر الإزالات الثلاث، من تذاكرها أو من تقنية المعلومات.

الإجابة: د5 بالأسئلة الأربعة

تصدير الحسابات النشطة · 2 يوليو 2026 · مقتطف 5 من 221 — نموذج تعليمي · بيانات افتراضية

المعرّف	الاسم	الدور	الحالة	آخر دخول
hr.n.alharbi	نوال الحربي	مسؤول الرواتب	نشط	1 يوليو 2026
hr.a.ghamdi	أمل الغامدي	تعديل الرواتب	نشط	28 يونيو 2026
fin.y.qahtani	ياسر القحطاني	عرض التقارير المالية	نشط	9 مايو 2026
hr.l.shammari	لمى الشمري	إدخال الحضور	نشط	21 مايو 2026
it.f.otaibi	فيصل العتيبي	مدير النظام	نشط	2 يوليو 2026

مغادرو مايو حسب الموارد البشرية: عبدالله الزهراني (7)، ياسر القحطاني (14)، لمى الشمري (28).

ما الذي نراه؟

ياسر القحطاني ولمى الشمري غادرا في مايو، وحساباهما نشطان في 2 يوليو.

ماذا يثبت؟

بقاء صلاحيات غير مبررة لحسابين بعد المغادرة.

ماذا لا يثبت؟

أنهما استُخدما بعد المغادرة، ولا حالة بقية المغادرين، فالمقتطف 5 صفوف.

ما المطلوب إضافةً؟

مطابقة كل المغادرين بالتصدير الكامل، وسجل نشاط الحسابين، وإبلاغ مالك الضابط 1-9-5.

الإجابة: النتيجة ومبررها

النتيجة
مطبق جزئياً

المتطلب موثق (د1) وطُبق في الربع الأول (د2)، لكنه لم يعمل باستمرار: الربع الثاني لم يُنفذ (د4)، و3 إزالات تأخرت (د3)، وبقيت صلاحيات غير مبررة (د5). اختيار «مطبق» يتجاهل نصف الفترة، واختيار «غير مطبق» يتجاهل ما نُفذ فعلاً.

أدلة إضافية قبل الإغلاق

- ✓ سجل تغيير ترحيل النظام لتأكيد التاريخ وهل منع المراجعة فعلاً.
- ✓ هل اعتُمد استثناء بتأجيل المراجعة وموعد بديل؟
- ✓ هل نُفذت مراجعة الربع الثاني لاحقاً في يوليو؟
- ✓ سبب تأخر الإزالات الثلاث من تذاكرها.

التطبيق 3: أخطاء شائعة

القاعدة التي تمنعها

- ابحث عن دليل لكل مستوى: موثق، ومطبق، ويعمل.
- النتيجة تعكس الفترة كاملة.
- المقابلة تفتح سؤالاً ولا تغلقه.
- التعميم يحتاج مبرراً.
- السبب يُتحقق منه بدليل.

أخطاء شائعة

- «مطبق» لأن المعيار موجود: الوثيقة لا تثبت التشغيل.
- «غير مطبق» مع تجاهل الربع الأول.
- الاعتماد على المقابلة وحدها دليلاً.
- تعميم: «كل الإزالات متأخرة» من 3 حالات من 12.
- اعتبار سبب البريد مؤكداً دون تحقق.

التصميم والتنفيذ والتشغيل: ثلاث فجوات مختلفة

1

ملاءمة التصميم

هل الضابط، كما صُمّم، يغطي الخطر والنطاق المطلوبين؟

الدليل: نص الإجراء أو المعيار، ونطاقه، ومقارنته بالخطر والأنظمة.

←

2

التنفيذ

هل طبقت الجهة الضابط فعلاً كما صُمّم؟

الدليل: أول تشغيل: إعداد، أو ملف، أو تذكرة بتاريخ.

←

3

فاعلية التشغيل

هل عمل وفق تصميمه، وبالتكرار المطلوب، طوال الفترة؟

الدليل: أدلة تغطي الفترة كلها: كل دورة، وكل عينة.

اسأل بالترتيب: لا معنى لاختبار تشغيل ضابط سيئ التصميم، أو ضابط لم يُطبق بعد.

وأسئلة الشريحة 91، موثق ومطبق ويعمل باستمرار، هي هذه الأسئلة من زاوية الأدلة.

مثال محلول (1 من 2): فجوة تصميم وفجوة تنفيذ

1. فجوة تصميم · البريد والملفات السحابية

ما صُمّم ووُثّق

إجراء مراجعة صلاحيات البريد PRC-AC-05، أبريل 2026: «يراجع مدير كل إدارة حسابات موظفي إدارته كل ستة أشهر».

الدليل

تصدير الحسابات: 203 حسابات، منها 4 حسابات إدارية لا تتبع أي إدارة: it-admin01 وit-admin02 وsanad-mail-admin وsvc-backup.

الاستنتاج

لا مدير يراجع الحسابات الإدارية، فهي خارج المراجعة بالتصميم. ولو نُفذ الإجراء بإتقان لبقيت أخطر الحسابات بلا مراجعة.

2. فجوة تنفيذ · تطبيق تتبع الشحنات

ما صُمّم ووُثّق

معيار التحكم بالوصول STD-AC-01، الإصدار 1.1 المعتمد في 15 مارس 2026: يضيف تطبيق التتبع، ومراجعة كل 3 أشهر، وأولها قبل 30 أبريل.

الدليل

لا ملف مراجعة ولا تصدير لمستخدمي التطبيق. بريد من تقنية المعلومات في 2 يوليو: «لم نحدد بعد من يصدّر قائمة المستخدمين».

الاستنتاج

الضابط مصمم وموثق ومعتمد، لكنه لم يُطبق مرة واحدة. لا معنى لاختبار فاعليته قبل أن يبدأ.

مثال محلول (2 من 2): فجوة تشغيل، ولماذا يهمك النوع

3. فجوة تشغيل · نظام الموارد البشرية والرواتب

ما صُمّم ووُثّق

المعيار نفسه، الإصدار 1.0: مراجعة كل 3 أشهر. وهو الضابط الذي فحصته في التطبيق 3.

الدليل

مراجعة الربع الأول منفذة ومعتمدة في 8 أبريل. لا ملف لمراجعة الربع الثاني حتى 30 يونيو.

الاستنتاج

الضابط صُمم جيداً وطُبق فعلاً، لكنه لم يعمل بالتكرار المطلوب طوال الفترة.

نوع الفجوة	العلاج المناسب	مثال من رُفاد
تصميم	تعديل الإجراء أو المعيار ليغطي الخطر والنطاق.	إضافة الحسابات الإدارية إلى مراجعة البريد بمراجع محدد.
تنفيذ	بدء التطبيق: مالك، وأداة، وموعد أول تشغيل.	تحديد من يصدّر مستخدمي تطبيق التتبع، وتنفيذ أول مراجعة.
تشغيل	استعادة الدورة المفقودة، ومتابعة تمنع التكرار.	مراجعة الربع الثاني، وجدول بتذكير آلي.

تمرين: ما نوع الفجوة؟

لكل موقف: ما نوع الفجوة: تصميم، أم تنفيذ، أم تشغيل؟ ولماذا؟ وما الدليل الذي يؤكد استنتاجك؟ 10 دقائق.

#	الموقف في رُفاد	نوع الفجوة ولماذا	الدليل
1	معيار الوصول عن بعد يفرض MFA على كل مستخدمي VPN، لكنه يسمح بـ«استثناءات مؤقتة» دون موافقة ولا مدة.		
2	سياسة الأطراف الخارجية المعتمدة في مايو 2026 تطلب بند إبلاغ عن الحوادث في كل عقد، ولم يُعدَّل عقد سَنَد ولم يُرسل له ملحق.		
3	معيار النسخ يطلب نسخة يومية لخادم التتبع، والمهمة مضبوطة يومياً، لكن تقرير المهام يُظهر 9 أيام فاشلة متتالية في مايو دون متابعة.		

الإجابة: ما نوع الفجوة؟

النوع	لماذا	الدليل الذي يؤكده
1. فجوة تصميم	الضابط كما كُتب يترك باباً مفتوحاً: استثناء بلا موافقة ولا مدة. هذا ما سمح بسياسة VPN-Legacy في التطبيق 3.	نص المعيار، وقائمة الاستثناءات القائمة وتواريخها.
2. فجوة تنفيذ	المتطلب مكتوب ومعتمد، لكنه لم يُطبق على العقد القائم.	السياسة المعتمدة، وعقد سَنَد الحالي، وأي مراسلة أو خطة لتعديله.
3. فجوة تشغيل	الضابط مصمم ومطبق، لكنه توقف 9 أيام دون أن يلاحظ أحد.	تقرير مهام النسخ للفترة كلها، وتذاكر المتابعة إن وُجدت.

⚠ خطأ شائع: تسمية كل فجوة «فجوة تشغيل». السؤال الأول دائماً: هل التصميم يغطي الخطر؟

الملاحظة: خمسة عناصر في نموذج واحد

ملاحظة

نموذج تعليمي · بيانات افتراضية

العنوان: الفجوة في سطر واحد، بلا لوم.

رقم الملاحظة: … الضابط: … الفترة: …

الوضع القائم	ما وجدته، بأرقام وتواريخ.
المعيار	المتطلب أو البند الذي يُقاس عليه.
السبب	لماذا حدث، بعد التحقق. وإلا فاكتب «سبب محتمل».
الأثر	ماذا يعني للجهة، بلغة العمل.
التوصية	ما يعالج السبب، لا العَرَض فقط.

1. **حقائق لا أحكام**
   «3 من 12 إزالة تأخرت»، لا «بعض الإزالات».
2. **السبب بعد التحقق**
   بريد أو انطباع ليس سبباً مؤكداً.
3. **صف العملية**
   لا تلُم أشخاصاً بالاسم.

خطة التصحيح: متتبع بإجراء ومالك وموعد ودليل

متتبع الإجراءات التصحيحية — نموذج تعليمي · بيانات افتراضية

الإجراء	المالك	الموعد	الحالة	دليل الإغلاق
معالجة الحالة: تزيل الخطر الآن				
ما الذي سيُنفذ تحديداً؟	شخص واحد بالوظيفة	تاريخ، لا «قريباً»	مفتوح	ما الذي يثبت الإنجاز؟
منع التكرار: يعالج السبب				
...	...	...	مفتوح	...

لا تُغلق الملاحظة بوعد. تُغلق بدليل، وبعد إعادة الاختبار.

قبول الخطر بدل التصحيح يوثقه صاحب الصلاحية، ولا يلغي أي التزام نظامي.

مثال محلول: الملاحظة (1 من 2): ماذا وجدنا ولماذا

ملاحظة

نموذج تعليمي · بيانات افتراضية

حسابات تتصل بالشبكة عن بعد دون تحقق متعدد العوامل

رقم الملاحظة: F-03 الضابط: ECC 2-2-3-2 الفترة: 1 يناير إلى 30 يونيو 2026

الوضع القائم	لم يكن التحقق متعدد العوامل مفروضاً على اتصالات VPN حتى 10 مارس 2026. وبعد التفعيل، اتصلت 3 حسابات من خارج مجموعة التحقق بكلمة المرور فقط، حددتها مطابقة المعرّفات وسجل الاتصالات، منها حساب لمستشار انتهى عقده.
المعيار	ECC 2-2-3-2، ومعيار الوصول عن بعد في رُفاد (فبراير 2026).
السبب	أُضيفت الحسابات الثلاثة يدوياً إلى سياسة استثناء «مؤقتة» عند التفعيل، دون إجراء موافقة أو مراجعة. تحققنا من ذلك بسجل التغييرات ومقابلة فريق تقنية المعلومات.

مثال محلول: الملاحظة (2 من 2): الأثر والتوصية

ملاحظة

نموذج تعليمي · بيانات افتراضية

حسابات تتصل بالشبكة عن بعد دون تحقق متعدد العوامل

رقم الملاحظة: F-03 الضابط: ECC 2-2-3-2 الفترة: 1 يناير إلى 30 يونيو 2026

الأثر	من يعرف كلمة مرور أحد الحسابات الثلاثة يستطيع دخول الشبكة الداخلية دون عامل ثانٍ، ومنها حساب لشخص لم يعد يعمل مع رُفاد.
التوصية	إزالة الاستثناءات الثلاثة، واعتماد إجراء للاستثناءات بموافقة ومدة ومراجعة، ومطابقة دورية بين مستخدمي VPN ومجموعة التحقق. التفاصيل في خطة التصحيح.

1 الأثر بلغة العمل
ماذا يعني لرُفاد، لا وصف تقني.

2 التوصية تعالج السبب
استثناءات بلا موافقة، لا الحسابات الثلاثة فقط.

3 التفاصيل في الخطة
المالك والموعد والدليل في الشريحة التالية.

مثال محلول: خطة التصحيح

متتبع الإجراءات التصحيحية — نموذج تعليمي · بيانات افتراضية

الإجراء	المالك	الموعد	الحالة	دليل الإغلاق
معالجة الحالة: تزيل الخطر الآن				
تعطيل حساب المستشار السابق	مدير تقنية المعلومات	يوم عمل واحد	مفتوح	تصدير يبين الحساب معطلاً، وسجل التغيير
نقل الحسابين إلى مجموعة التحقق أو تعطيلهما	مدير تقنية المعلومات	5 أيام عمل	مفتوح	تصدير المجموعة، وسجل VPN لأسبوع
منع التكرار: يعالج السبب				
اعتماد إجراء استثناءات بموافقة ومدة ومراجعة	مسؤولة GRC	30 يوماً	مفتوح	الإجراء المعتمد، وسجل الاستثناءات
مطابقة شهرية: مستخدمو VPN مقابل المجموعة	مدير تقنية المعلومات	بدءاً من الشهر القادم	مفتوح	تقارير 3 أشهر متتالية

دورك: ملاحظة وخطة تصحيح لنظام الرواتب

1. اكتب ملاحظة بعناصرها الخمسة لنتيجة التطبيق 3 (مراجعة صلاحيات نظام الرواتب).
2. السبب: افترض أنك تحققت من سجل الترحيل ووجدت أنه لم يُعتمد أي استثناء لتأجيل المراجعة.
3. اكتب خطة تصحيح من 4 إجراءات: المالك، والموعد، ودليل الإغلاق.

نتيجتك في التطبيق 3: مطبق جزئياً

- ✓ الربع الأول نُفذ واعتُمد في موعده.
- ✓ الربع الثاني لم يُنفذ حتى 30 يونيو.
- ✓ 3 من 12 إزالة تأخرت عن مهلة 5 أيام عمل.
- ✓ في 2 يوليو: حسابان لمغادرين في مايو ما زالا نشطين.

دورك: النموذج

العنوان

الوضع القائم

أرقام وتواريخ...

المعيار

السبب

ما تحققت منه...

الأثر

التوصية

ما يعالج السبب

وجدول خطة التصحيح في الكراسة: الإجراء، والمالك، والموعد، ودليل الإغلاق. 20 دقيقة.

الإجابة: الملاحظة (1 من 2)

ملاحظة

نموذج تعليمي · بيانات افتراضية

عدم انتظام المراجعة الدورية لصلاحيات نظام الموارد البشرية والرواتب

رقم الملاحظة: F-04 الضابط: ECC 2-2-3-5 الفترة: 1 يناير إلى 30 يونيو 2026

الوضع القائم	نُفذت مراجعة الربع الأول واعتُمدت في موعدها، لكن 3 من 12 إزالة نُفذت بعد 6 أسابيع، ولم تُنفذ مراجعة الربع الثاني حتى 30 يونيو 2026. وفي 2 يوليو كان حسابان لموظفين غادروا في مايو ما زالا نشطين.
المعيار	ECC 2-2-3-5، ومعيار التحكم بالوصول (يناير 2026): مراجعة كل 3 أشهر، وإزالة خلال 5 أيام عمل.
السبب	أُجّلت مراجعة الربع الثاني بسبب ترحيل النظام دون استثناء معتمد أو موعد بديل، ولا توجد متابعة لتذاكر الإزالة المتأخرة. تحققنا من ذلك بسجل الترحيل وتذاكر الإزالة.

الإجابة: الملاحظة (2 من 2)

ملاحظة

نموذج تعليمي · بيانات افتراضية

عدم انتظام المراجعة الدورية لصلاحيات نظام الموارد البشرية والرواتب

رقم الملاحظة: F-04 الضابط: ECC 2-2-3-5 الفترة: 1 يناير إلى 30 يونيو 2026

الأثر بقاء صلاحيات غير مبررة على رواتب الموظفين وحساباتهم البنكية، منها حسابان لمغادرين.

التوصية تعطيل حسابي المغادرين فوراً، وإكمال مراجعة الربع الثاني، واعتماد جدول مراجعات ببديل معتمد عند التعارض، ومتابعة تذاكر الإزالة. التفاصيل في خطة التصحيح.

1 الأثر

رواتب الموظفين وحساباتهم البنكية.

2 التوصية

إجراء فوري، ثم ما يمنع التكرار.

3 بلا لوم

العملية هي التي فشلت، لا شخص بالاسم.

الإجابة: خطة التصحيح وإعادة الاختبار

متتبع الإجراءات التصحيحية — نموذج تعليمي · بيانات افتراضية

الإجراء	المالك	الموعد	الحالة	دليل الإغلاق
معالجة الحالة: تزيل الخطر الآن				
تعطيل حسابي المغادرين ومراجعة نشاطهما بعد المغادرة	مدير تقنية المعلومات	يوما عمل	مفتوح	تصدير الحسابات، ونتيجة مراجعة السجل
تنفيذ مراجعة الربع الثاني واعتمادها	مديرة الموارد البشرية	15 يوم عمل	مفتوح	ملف المراجعة المعتمد، وتذاكر الإزالة
منع التكرار: يعالج السبب				
جدول مراجعات سنوي بتذكير آلي وبديل معتمد عند التعارض	مديرة الموارد البشرية	30 يوماً	مفتوح	الجدول المعتمد، وإعداد التذكير
متابعة أسبوعية لتذاكر الإزالة المفتوحة	مدير تقنية المعلومات	فوراً	مفتوح	تقرير التذاكر الأسبوعي

تعيد GRC الاختبار بعد مراجعة الربع الثالث، ولا تُغلق الملاحظة إلا بأدلة الإغلاق.

التطبيق 4: أخطاء شائعة

ما يجعل الإجابة قوية

- الوضع القائم أرقام وتواريخ، لا أحكام عامة.
- السبب مُتحقق منه، ويعالج العملية لا الأشخاص.
- كل إجراء له مالك واحد باسم الوظيفة، وموعد، ودليل إغلاق.
- إجراء فوري لإزالة الخطر، وإجراءات تمنع التكرار.

أخطاء شائعة

- لوم شخص بالاسم بدل العملية.
- مالك عام: «تقنية المعلومات» أو «الجميع».
- إجراء بلا موعد أو دليل إغلاق.
- الاكتفاء بتوصية «تدريب الموظفين».
- إغلاق الملاحظة بوعد بدل دليل.

المؤشرات: KGI وKPI وKRI وKCI

KGI

مؤشر تحقق الهدف

هل تحقق هدف العمل؟

في رُفاد: نسبة إتاحة تطبيق التتبع الشهرية، والالتزام 99%.

KPI

مؤشر الأداء

هل تُنفَّذ العملية جيداً؟

في رُفاد: متوسط أيام العمل لإغلاق تذاكر إزالة الصلاحيات، والمعيار 5.

KRI

مؤشر الخطر

هل يرتفع التعرض للخطر؟

في رُفاد: عدد الثغرات الحرجة المفتوحة أكثر من 14 يوماً في خادم التتبع.

KCI

مؤشر الضابط

هل يعمل الضابط كما صُمّم؟

في رُفاد: نسبة مراجعات الصلاحيات المعتمدة في موعدها.

⚠ التصنيف بالغرض، لا بالرقم: المؤشر نفسه قد يكون KPI في جهة وKCI في أخرى. اكتب في تعريفه ماذا يقيس، ولماذا.

تعريف المؤشر: ستة أسئلة قبل أي رقم

	KGI · إتاحة التتبع	KPI · إغلاق تذاكر الإزالة	KRI · الثغرات الحرجة	KCI · مراجعات الصلاحيات
الحساب	ساعات الإتاحة ÷ ساعات الشهر × 100.	متوسط أيام العمل من الاعتماد إلى الإغلاق.	عدد الحرجة المفتوحة أكثر من 14 يوماً.	المعتمدة في موعدها ÷ المجدولة × 100.
المصدر	تقرير المراقبة الشهري من سَنَد.	نظام التذاكر.	تقرير فحص الثغرات.	ملفات المراجعة وجدولها.
المالك	م. سلمان	م. سلمان	م. سلمان، وسَنَد ينفذ	أ. منى، وتجمعه أ. ريم
الدورية	شهري	شهري	شهري	ربع سنوي
يستدعي إجراءً	أقل من 99%: سبب وخطة خلال أسبوع.	أكثر من 5 أيام عمل.	أكبر من صفر. ويُصعَّد للجنة إن تجاوز عمرها 30 يوماً.	أقل من 100%.

وماذا يقيس كل مؤشر؟ في الشريحة السابقة. والقيم تدريبية.

تقرير الإدارة (1 من 2): المخاطر والمؤشرات

تقرير ربع سنوي للجنة · 1 من 2
لجنة الأمن السيبراني · الربع الثالث 2026 · 30 سبتمبر 2026 · أ. ريم، مسؤولة GRC

نموذج تعليمي · بيانات افتراضية

1. أهم المخاطر

الخطر	المستوى	الحالة	المالك
تأخر ترقيع ثغرات خادم التتبع	16 · عالٍ	معالجة إلزامية: ينتظر قرار الكلفة	م. سلمان
حساب المورد المشترك على خادم التتبع	16 · عالٍ	3 من 5 إجراءات منجزة	م. سلمان
ملفات الرواتب على حاسوب الأخصائي	6 · منخفض	عولج: الجهاز مشفر	أ. منى

2. المؤشرات

المؤشر	القيمة	المرجع	الحالة
KGI · إتاحة التتبع	99.4%	الهدف 99%	ضمن الحد
KPI · إغلاق تذاكر الإزالة	3.2 يوم عمل	المعيار 5	ضمن الحد
KRI · ثغرات حرجة أكثر من 14 يوماً	3	الحد صفر	يتجاوز الحد
KCI · مراجعات الصلاحيات في موعدها	100%	الربع الثالث	ضمن الحد

تقرير الإدارة (2 من 2): الملاحظات والإجراءات والقرارات

تقرير ربع سنوي للجنة · 2 من 2
لجنة الأمن السيبراني · الربع الثالث 2026 · 30 سبتمبر 2026 · أ. ريم، مسؤولة GRC

نموذج تعليمي · بيانات افتراضية

3. الملاحظات المتأخرة والمفتوحة

الملاحظة	الوضع	الموعد
F-03 · VPN دون MFA	3 من 4 إجراءات منجزة. المطابقة الشهرية بدأت في أغسطس.	في موعدها
F-04 · مراجعة صلاحيات الرواتب	جدول المراجعات السنوي لم يُعتمد بعد.	متأخر 20 يوماً

4. حالة إجراءات التصحيح

5
منجزة

2
جارية في موعدها

1
متأخرة

5. القرارات المطلوبة من اللجنة

1. اعتماد كلفة ترقيع عاجل لخادم التتبع من سَنَد خارج العقد الحالي.
2. تكليف المدير المالي بإضافة مهلة الترقيع وبند الإبلاغ عن الحوادث إلى عقد سَنَد عند تجديده.

تمرين: صنّف المؤشرات وعرّف واحداً

صنّف كل مؤشر واذكر غرضه، ثم اكتب تعريفاً كاملاً للمؤشر الثاني بالأسئلة الستة. 12 دقيقة.

#	المؤشر	نوعه وغرضه
1	نسبة الطلبات المسلّمة في موعدها.	
2	عدد الحسابات النشطة لموظفين غادروا، في نظام الرواتب.	
3	نسبة اتصالات VPN التي تمت بعاملٍ ثانٍ.	
4	نسبة الموظفين الجدد الذين أكملوا التوعية في أسبوعهم الأول.	

الإجابة: الأنواع، وتعريف مؤشر الخطر

#	النوع	لماذا
1	**KGI**	يقيس تحقق هدف عمل: التوصيل في الموعد.
2	**KRI**	يقيس تعرضاً للخطر: كل حساب منها باب مفتوح لشخص خارج الشركة.
3	**KCI**	يقيس هل يعمل ضابط MFA على كل الاتصالات، كما رأيت في التطبيق 3.
4	**KPI أو KCI**	يعتمد على الغرض: إن كان لمتابعة عملية التهيئة فهو KPI، وإن كان لإثبات أن ضابط التوعية يعمل فهو KCI. اكتب الغرض في تعريفه.

تعريف المؤشر الثاني (KRI):

ماذا يقيس؟: من غادر وما زال حسابه نشطاً في نظام الرواتب.	طريقة الحساب: عدد الحسابات النشطة لأصحابها في قائمة المغادرين.	المصدر: قائمة المغادرين من الموارد البشرية، وتصدير الحسابات النشطة.	المالك: أ. منى، وتقنية المعلومات تعطّل.	الدورية: شهري	ما يستدعي إجراءً: أي رقم أكبر من صفر: تعطيل خلال يوم عمل، وإبلاغ مالك ضابط المغادرين.

أداة GRC: كيف ترتبط المتطلبات والضوابط والأدلة والمخاطر

سجل GRC · رُفاد · ورقة الربط — نموذج تعليمي · بيانات افتراضية

المتطلب	الضابط	الدليل	الخطر	الملاحظة	الإجراء
ECC 2-2-3-5	CTL-AC-03 مراجعة الرواتب الفصلية	EV-21 ملف المراجعة · EV-22 التذاكر	R-12 صلاحيات غير مبررة	F-04	CAP-04-1 إلى 4
ECC 2-2-3-2	CTL-RA-01 MFA على VPN	EV-11 الإعداد · EV-13 المطابقة	R-09 دخول بكلمة مرور فقط	F-03	CAP-03-1 إلى 4
ECC 4-1-2	CTL-TP-02 بنود عقود الموردين	EV-31 عقد سَنَد	R-15 حساب المورد المشترك	—	خطة المعالجة

رقم واحد يربط كل شيء: من الملاحظة F-04 تصل إلى المتطلب والضابط والدليل والخطر والإجراءات. المنصات المتخصصة تفعل الشيء نفسه بجداول مرتبطة.

الصورة كاملة: كيف ترتبط الحلقات في رُفاد

قرار
التحقق متعدد العوامل إلزامي
الشريحة 34

←

سياسة
بند المراجعة الدورية
الشريحة 48

←

خطر
حساب المورد المشترك
الشريحة 80

←

ضابط
مراجعة ربع سنوية
الشريحة 89

دليل
ملفات المراجعة والتذاكر
الشريحة 104

←

ملاحظة
مراجعة غير منتظمة
الشريحة 127

←

تصحيح
إجراءات بمالك وموعد
الشريحة 129

هذه هي GRC في جهة واحدة: كل حلقة تعتمد على التي قبلها. والتطبيقات الأربعة غطت الحلقات كلها.

اختبار قصير: الوحدة 03

5

أسئلة قصيرة

10 دقائق

ما يغطيه الاختبار:

- ✓ الأدوار وRACI وصياغة الخطر.
- ✓ الخطر المتأصل والمتبقي.
- ✓ فجوات التصميم والتنفيذ والتشغيل، والمؤشرات.

أوقف الفيديو، وأجب في الكراسة في قسم «اختبار الوحدة 03». ثم قارن بالإجابات المفسرة، وانتبه لسبب خطأ كل بديل.

04 الأطر والانطباق

لا تحتاج أن تحفظ كل الأطر. تحتاج أن تعرف ماذا يفعل كل منها، ولمن هو، وكيف تحدد ما ينطبق على الجهة.

بعد هذه الوحدة ستستطيع أن:

- تفرق بين النظام والضابط والإطار والمعيار، وبين الملزم والاختياري.
- تعرف المراجع الرئيسية بعمق، ومراجع القطاع والبيانات بمقدمة.
- تحدد ما ينطبق على جهة، وتربط ضابطاً داخلياً بمرجعين وتحكم على التغطية.

نظام، وضوابط، وإطار، ومعيار: ما الفرق؟

النوع	هل هو ملزم؟	مثال
نظام أو تشريع	ملزم بقوة القانون لمن يقع في نطاقه	نظام حماية البيانات الشخصية
ضوابط تنظيمية	ملزمة للجهات التي يحددها نطاقها	ECC-2:2024 للجهات المشمولة
إطار	يرشد ويرتب العمل، وغالباً طوعي	NIST CSF 2.0
معيار قابل للشهادة	طوعي، تُمنح عليه شهادة من جهة مانحة	ISO/IEC 27001
التزام تعاقدي	ملزم بالعقد لا بالقانون	PCI DSS عبر العقود مع شبكات البطاقات

السؤال الأول دائماً: هل هذا المرجع ملزم لهذه الجهة تحديداً، أم اختارته طوعاً؟

ليست كل المراجع بالعمق نفسه

رئيسي في الكورس

تفهم بنيته وتطبق منه.

- ECC-2:2024
- الإطار الوطني لإدارة المخاطر NFCRM-1:2025
- ISO/IEC 27001:2022
- NIST CSF 2.0

مقدمة حسب القطاع والبيانات

تعرف لمن ينطبق، ولماذا.

- إطار ساما للأمن السيبراني
- نظام حماية البيانات الشخصية
- PCI DSS v4.0.1
- GDPR

تعريف ومقارنة

تعرف نوعه وموقعه.

- COBIT 2019
- CIS Controls v8.1
- NIST RMF
- HIPAA
- SOX

وستقابل أيضاً ISO 22301 للاستمرارية، وISO/IEC 27701 للخصوصية، وNIST SP 800-53، وCOSO، وتقارير SOC 2. لا تحفظ قوائم الضوابط؛ اعرف النوع والغرض والنطاق.

مراجع القطاع والبيانات: لمن تنطبق؟

المرجع ونوعه	الغرض	نطاق الانطباق	لماذا قد تستخدمه الجهة؟
إطار ساما (2017): إطار تنظيمي قطاعي	الأمن السيبراني في القطاع المالي	الخاضعون لإشراف البنك المركزي: البنوك، والتأمين، والتمويل، ومكاتب الائتمان، وغيرها	ملزم لهم، ويُطلب من مزوديهم أحياناً
نظام حماية البيانات الشخصية: نظام (قانون)	حقوق صاحب البيانات وضوابط معالجتها	معالجة البيانات الشخصية المتعلقة بأفراد في المملكة، ومنها المعالجة من خارجها	ملزم لمن يقع في نطاقه، ومنهم رُفاد
PCI DSS v4.0.1: معيار تعاقدي من مجلس PCI SSC	حماية بيانات البطاقات	من يخزن بيانات البطاقات أو يعالجها أو ينقلها	تفرضه شبكات البطاقات والبنوك المستحوذة بالعقود
GDPR: لائحة أوروبية	حماية البيانات الشخصية	منشأة في الاتحاد الأوروبي، أو من يعرض سلعاً وخدمات لأفراد فيه أو يراقب سلوكهم	شركة سعودية تخدم عملاء في أوروبا

مراجع للتعريف والمقارنة

المرجع ونوعه	الغرض	نطاق الانطباق	لماذا قد تستخدمه الجهة؟
COBIT 2019: إطار حوكمة وإدارة للتقنية من ISACA	ربط التقنية بأهداف الجهة	أي جهة، طوعاً	لحوكمة التقنية وتدقيقها
CIS Controls v8.1: ضوابط مرتبة بالأولوية من CIS	18 ضابطاً و153 إجراءً، ومجموعات تنفيذ IG1 إلى IG3	أي جهة، طوعاً	بداية عملية: IG1 «النظافة السيبرانية الأساسية»
NIST RMF: عملية لإدارة مخاطر الأنظمة من NIST	سبع خطوات من التهيئة إلى المراقبة	مصممة للأنظمة الفيدرالية الأمريكية	منهجية لإدارة مخاطر نظام عبر دورة حياته
HIPAA: قانون أمريكي	حماية المعلومات الصحية	خطط التأمين الصحي ومقدمو الرعاية المشمولون وشركاؤهم	جهة تعالج بيانات صحية لصالح جهة أمريكية
SOX: قانون أمريكي (2002)	موثوقية التقارير المالية	الشركات المدرجة في الولايات المتحدة؛ القسم 404 للرقابة الداخلية	ضوابط التقنية التي تمس التقارير المالية

ISO/IEC 27001:2022: البنود الإلزامية

خطّط Plan

- **4** السياق والنطاق
- **5** القيادة والسياسة
- **6** التخطيط وتقييم المخاطر
- **7** الدعم والموارد

نفّذ Do

- **8** التشغيل ومعالجة المخاطر

تحقّق Check

- **9** تقييم الأداء والتدقيق الداخلي

حسّن Act

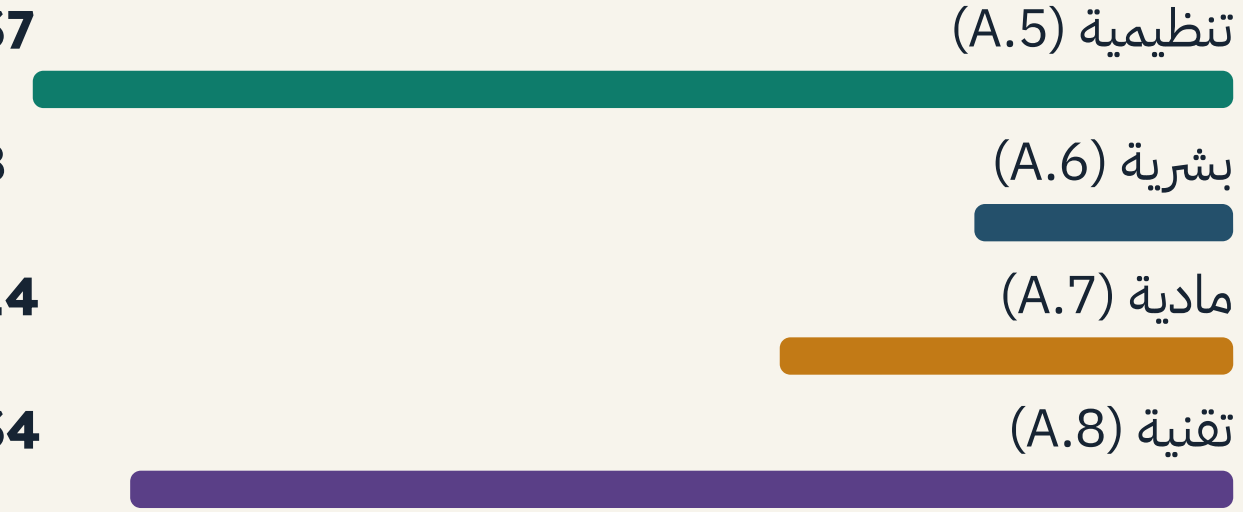
- **10** التحسين المستمر

ثم تعود الدورة: التحسين يغذي التخطيط في الدورة التالية.

مسار الشهادة تدقيق المرحلة 1 للوثائق، ثم المرحلة 2 للتطبيق، ثم شهادة لثلاث سنوات مع تدقيق متابعة سنوي.

ISO/IEC 27001: الملحق A وبيان قابلية التطبيق

الملحق A: 93 ضابطاً في 4 محاور



بيان قابلية التطبيق (SoA)

لا تطبق كل الضوابط تلقائياً. تختار ما يلزم من تقييم المخاطر، وتوثق المطبق والمستبعد ومبرر كل منهما.

المعيار المرافق ISO/IEC 27002 يشرح كل ضابط بالتفصيل.

NIST CSF 2.0: ست وظائف، والحوكمة في المركز

GV

الحوكمة · Govern · جديدة في 2.0

الاستراتيجية، والأدوار، والسياسات، ومخاطر سلسلة الإمداد. هنا يعمل GRC مباشرة.

ID
التحديد
الأصول والمخاطر

PR
الحماية
الهويات والبيانات والمنصات

DE
الاكتشاف
المراقبة وتحليل الأحداث

RS
الاستجابة
إدارة الحادثة

RC
التعافي
استعادة العمليات

NIST CSF: المستويات والملفات التعريفية

المستويات تصف مدى صرامة ممارسات الجهة في حوكمة مخاطر الأمن السيبراني وإدارتها، من استجابة غير رسمية إلى نهج متكيف ومستمر التحسين.

1	2	3	4
جزئي	**مطلع على المخاطر**	**قابل للتكرار**	**متكيف**
Partial	Risk Informed	Repeatable	Adaptive

كيف تُستخدم

- ✓ تختارها القيادة للجهة كلها، أو لوظيفة أو فئة.
- ✓ توجه الملفين الحالي والمستهدف.
- ✓ الانتقال لمستوى أعلى عند حاجة المخاطر أو الالتزامات.

ما ليست عليه

- ⚠ ليست درجة نضج لكل ضابط.
- ⚠ لا تحل محل منهجية إدارة المخاطر.
- ⚠ لا يُشترط أن تكون كل جهة في المستوى 4.

مقارنتان تخلطهما المقابلات

NIST CSF أم NIST RMF؟

	CSF 2.0	RMF
النوع	إطار نتائج لإدارة مخاطر الأمن السيبراني	عملية من سبع خطوات
المستوى	الجهة كلها: ملفات ومستويات	نظام واحد عبر دورة حياته
المرجع	CSWP 29 · 2024	SP 800-37 Rev. 2

تقييم الفجوات أم النضج؟

	Gap Assessment	Maturity Assessment
السؤال	ما الفرق بين الوضع القائم ومتطلب محدد؟	إلى أي مستوى وصلت ممارسات الجهة؟
النتيجة	قائمة فجوات: مطبق، جزئي، غير مطبق	مستوى على مقياس نضج
في رُفاد	تقييم النصف الأول 2026	لم يُجرَ بعد

خطوات RMF السبع: Prepare · Categorize · Select · Implement · Assess · Authorize · Monitor

الأطر السعودية: ضوابط الهيئة الوطنية للأمن السيبراني

الضوابط	موضوعها ونطاقها المختصر
ECC-2:2024	الضوابط الأساسية: 108 ضوابط للجهات الحكومية والتابعة لها وجهات البنية التحتية الوطنية الحساسة
CCC-2:2024	الحوسبة السحابية: لمقدمي الخدمات السحابية والمستفيدين منها
DCC-1:2022	البيانات: حمايتها في دورة حياتها
CSCC-1:2019	الأنظمة الحساسة الوطنية
OTCC-1:2022	أنظمة التقنية التشغيلية والتحكم الصناعي
TCC-1:2021	العمل عن بعد
OSMACC-1:2021	حسابات التواصل الاجتماعي للجهات

الضوابط الأخرى امتداد لـ ECC في سياقات محددة. النطاق الدقيق في النص الرسمي لكل منها.

الأطر السعودية: مراجع أخرى تهمك

المرجع	الجهة	لمن
الإطار الوطني لإدارة مخاطر الأمن السيبراني NFCRM-1:2025	الهيئة الوطنية للأمن السيبراني	نطاق ECC نفسه
إطار ساما للأمن السيبراني، الإصدار 1.0 (2017)	البنك المركزي السعودي	الجهات المالية الخاضعة لإشرافه
نظام حماية البيانات الشخصية ولوائحه	سدايا	من يعالج بيانات شخصية في المملكة
معايير إدارة البيانات وحماية البيانات الشخصية v1.5	مكتب إدارة البيانات الوطنية	الجهات العامة وشركاؤها
الإطار السعودي لكوادر الأمن السيبراني SCyWF-1.5:2026	الهيئة الوطنية للأمن السيبراني	الأدوار الوظيفية ومهامها

للمسار المهني: SCyWF فيه فئة «الحوكمة والمخاطر والامتثال والأنظمة» بأدوارها. استخدم أسماءها في سيرتك.

كيف تحدد ما ينطبق على الجهة؟ أربعة أسئلة

1 نوع الجهة

حكومية، أم تابعة لجهة حكومية، أم تملك بنية حساسة، أم خاصة؟

2 القطاع والمنظم

هل تخضع لجهة رقابية قطاعية، مثل البنك المركزي؟

3 نوع البيانات

بيانات شخصية؟ بيانات بطاقات؟ بيانات حكومية؟

4 العقود والعملاء

هل تفرض العقود متطلبات أمن على الجهة؟

ثم تحقق من نص «نطاق التطبيق» في المرجع الرسمي نفسه. لا تحكم من اسم الإطار.

تمرين: ما الذي ينطبق على كل جهة؟

رُفاد شركة خاصة للتوصيل، تعالج بيانات موظفين ومستلمين، لا تعالج بيانات بطاقات بنفسها.

شركة «مدى التقنية» شركة افتراضية تابعة لوزارة، تقدم خدمات تقنية للوزارة.

شركة «دفع سريع» شركة تقنية مالية افتراضية مرخصة من البنك المركزي السعودي، تعالج مدفوعات بالبطاقات.

الجهة	ECC-2:2024	نظام حماية البيانات الشخصية	إطار ساما للأمن السيبراني	PCI DSS
رُفاد				
شركة «مدى التقنية»				
شركة «دفع سريع»				

لكل خانة: نعم، أو لا، أو يعتمد، مع سبب قصير. 10 دقائق.

الإجابة: الانطباق على الجهات الثلاث

الجهة	ECC-2:2024	نظام حماية البيانات الشخصية	إطار ساما للأمن السيبراني	PCI DSS
رُفاد	غير ملزم؛ تبنته طوعاً	نعم	لا	لا، ما دامت لا تخزن بيانات البطاقات أو تعالجها أو تنقلها
مدى التقنية	نعم: تابعة لجهة حكومية	نعم إن عالجت بيانات شخصية	لا	حسب معالجتها للبطاقات
دفع سريع	لا، ما لم تكن حكومية أو بنية تحتية حساسة	نعم	غالباً نعم: تحقق من نطاق الإطار في دليل ساما	نعم: تعالج بيانات البطاقات

الإجابة: قاعدة الانطباق والأخطاء الشائعة

ما يجعل الإجابة قوية

- الانطباق يُحدَّد من النص الرسمي لنطاق كل إطار، لا من اسمه.
- النوع (حكومي أو خاص)، والقطاع، ونوع البيانات، والعقود: أربعة أسئلة تكفي للبداية.
- الإطار غير الملزم يمكن تبنيه طوعاً، لكن لا تصف الجهة بأنها «ملتزمة نظاماً» به.

أخطاء شائعة

- افتراض أن ECC تلزم كل شركة سعودية.
- نسيان نظام حماية البيانات الشخصية لأن الجهة ليست تقنية.
- الجزم بالانطباق دون الرجوع إلى نص النطاق.

مثال محلول: مواءمة ضابط واحد مع مرجعين

الضابط الداخلي: CTL-RA-01: التحقق متعدد العوامل إلزامي لكل مستخدمي VPN (معيار الوصول عن بعد، فبراير 2026).

المرجع	ماذا يطلب، بإيجاز	ماذا يغطي ضابط رُفاد	التغطية
ECC 2-2-3-2	تحقق متعدد العوامل للدخول عن بعد وللحسابات ذات الصلاحيات الهامة، بعوامل يحددها تقييم الأثر.	يغطي الدخول عن بعد عبر VPN فقط.	**جزئي: الحسابات الهامة لها ضابط آخر يجب ربطه.**
ISO/IEC 27001 A.8.5	المصادقة الآمنة: تقنيات وإجراءات مصادقة آمنة وفق قيود الوصول.	جزء منها: MFA على VPN.	**جزئي: يخدم جزءاً من الضابط.**

الأدلة: إعداد سياسة البوابة، وسجل التغييرات، وسجل الاتصالات بطريقة التحقق: الأدلة نفسها تخدم المرجعين.

المواءمة توفر الجهد، لكنها لا تثبت الالتزام: نتيجة التطبيق 3 «مطبق جزئياً» تنطبق على المرجعين معاً.

تمرين: مواءمة مراجعة الصلاحيات

الضابط الداخلي: CTL-AC-03: مراجعة صلاحيات نظام الرواتب كل 3 أشهر، وإزالة غير المبرر خلال 5 أيام عمل (STD-AC-01).

المرجع	ماذا يطلب، بإيجاز	ماذا يغطي ضابط رُفاد	التغطية
ECC 2-2-3-5	المراجعة الدورية لهويات الدخول والصلاحيات.		
ISO/IEC 27001 A.5.18	صلاحيات الوصول: منحها ومراجعتها وتعديلها وإزالتها.		

أكمل: ماذا يغطي الضابط من كل مرجع؟ كلي أم جزئي، ولماذا؟ وما الأدلة التي تخدم الاثنين؟ 10 دقائق.

الإجابة: مواءمتان جزئيتان

المرجع	التغطية	لماذا
ECC 2-2-3-5	جزئي	الضابط يغطي نظام الرواتب، ثم تطبيق التتبع من الإصدار 1.1. البريد يغطيه إجراء آخر بفجوة في الحسابات الإدارية، وVPN بلا مراجعة.
ISO A.5.18	جزئي	الضابط يخدم المراجعة والإزالة، ولا يغطي منح الصلاحيات وتعديلها.
الأدلة	مشتركة	ملف المراجعة واعتماده يخدمان المراجعة في المرجعين، وتذاكر الإزالة تخدم الإزالة في ISO.

⚠ لا تكتب «متوافق» لأن العنوانين متشابهان. اكتب ما يغطيه الضابط، وما ينقص، وأي دليل يثبت ماذا.

بأي إطار تبدأ؟ وكيف تقرؤه؟

1
NIST CSF 2.0
مجاني، ويعطيك الصورة الكاملة.

2
ISO/IEC 27001
منطق نظام الإدارة، وكثير الطلب.

3
إطار قطاعك
حكومي: ECC. بنوك: SAMA CSF.
مدفوعات: PCI DSS.

مع كل ضابط تقرؤه، اسأل:

1. ما الخطر الذي يعالجه؟
2. كيف يبدو تطبيقه في جهة حقيقية؟
3. ما الدليل الذي يثبت تطبيقه؟
4. ما الذي يقابله في إطار آخر؟

اختبار قصير: الوحدة 04

4

أسئلة قصيرة

8 دقائق

ما يغطيه الاختبار:

- ✓ الإلزام والانطباق.
- ✓ المواءمة الكلية والجزئية.
- ✓ CSF مقابل RMF، والفجوات مقابل النضج.

أوقف الفيديو، وأجب في الكراسة في قسم «اختبار الوحدة 04». ثم قارن بالإجابات المفسرة، وانتبه لسبب خطأ كل بديل.

05 الشهادات

أي شهادة تناسب هدفك ومرحلتك؟ ماذا تعلّمك، وهل تشترط خبرة، ومتى تدرسها؟

بعد هذه الوحدة ستستطيع أن:

- تعرف الشهادات الأهم في GRC والأمن والخصوصية، ولمن تناسب كل منها.
- تفرق بين شهادة التدريب، والنجاح في الاختبار، واللقب المهني.
- تختار مسارك حسب الوظيفة المستهدفة، وتعرف كيف تذاكر.

خريطة الشهادات: ثلاث مراحل

البداية

بلا خبرة: تثبت الأساسيات.

ISC2	**CC**
CompTIA	**Security+**
ISACA	**IT Risk Fund.**

التخصص

مهارة محددة في GRC أو معيار.

جهات مانحة	**ISO 27001 LI/LA**
OCEG	**GRCP**
IAPP	**CIPP/E · CIPM**

بعد اكتمال الخبرة

تُمنح بعد سنوات خبرة موثقة.

ISACA	**CISA · CISM**
ISACA	**CRISC · CGEIT**
ISC2	**CGRC · CISSP**
ISACA	**CDPSE**

شهادات البداية: CC و+Security

ISC2 CC
Certified in Cybersecurity

لمن؟ خريج أو متحول بلا خبرة.

ماذا تعلّم؟ مبادئ الأمن، والحوكمة الأمنية، والهويات، والشبكات والسحابة، والعمليات.

الخبرة لا تشترط خبرة.

متى؟ الآن: أول شهادة.

CompTIA Security+
CompTIA Security+

لمن؟ من يريد أساساً تقنياً أعمق.

ماذا تعلّم؟ التهديدات، والمعمارية، والعمليات، وإدارة البرنامج الأمني.

الخبرة لا شرط رسمي؛ يُنصح بخبرة سنتين.

متى؟ الآن أو بعد CC، حسب خلفيتك.

⚠ انتهى عرض اختبار CC المجاني من ISC2: أُغلق التسجيل فيه في 20 مايو 2026.

مدخل إلى GRC والمخاطر: GRCP وIT Risk Fundamentals

OCEG GRCP
GRC Professional

لمن؟ من يريد أساساً في GRC نفسه.

ماذا تعلّم؟ مفاهيم GRC ونموذج OCEG للقدرات.

الخبرة لا تشترط خبرة.

متى؟ مبكراً، بعد الأساسيات.

ISACA IT Risk Fundamentals
IT Risk Fundamentals Certificate

لمن؟ مبتدئ يتجه إلى مخاطر التقنية.

ماذا تعلّم؟ أساسيات مخاطر تقنية المعلومات.

الخبرة لا شرط. شهادة إتمام، لا اعتماد مهني.

متى؟ الآن.

ISO 27001: منفذ رئيسي أم مدقق رئيسي؟

Lead Implementer PECB وجهات أخرى
ISO/IEC 27001 Lead Implementer

لمن؟ من سيبني نظام إدارة أمن المعلومات أو يستشير فيه.

ماذا تعلّم؟ تخطيط النظام وتطبيقه ومتابعته وفق البنود 4 إلى 10.

الخبرة الاختبار بلا خبرة، واللقب يحتاج خبرة.

متى؟ إن اتجهت للتطبيق والاستشارات.

Lead Auditor PECB وجهات أخرى
ISO/IEC 27001 Lead Auditor

لمن؟ من سيدقق أنظمة الإدارة داخلياً أو لدى جهة مانحة.

ماذا تعلّم؟ تخطيط التدقيق وتنفيذه، وكتابة الملاحظات وإعداد التقرير.

الخبرة الاختبار بلا خبرة، واللقب يحتاج خبرة تدقيق.

متى؟ إن اتجهت للتدقيق.

لا تصدرها ISO نفسها، بل جهات تدريب واعتماد مثل PECB وBSI. شروط كل جهة تختلف.

شهادات ISO: التدريب ليس الاختبار، والاختبار ليس اللقب

1

إتمام التدريب

شهادة حضور أو إتمام. عند PECB: 31 ساعة تطوير مهني.

2

النجاح في الاختبار

← عند PECB: 80 سؤالاً بكتاب مفتوح، والنجاح 70%.

3

استحقاق اللقب

← Provisional بلا خبرة، ثم Implementer، ثم Lead، ثم Senior Lead.

4

متطلبات الجهة

← كل جهة مانحة لها شروطها. شهادة PECB تختلف عن غيرها.

قد تجد دورات تُشرح بالعربية، لكن لغة الاختبار شيء آخر. تحقق منها في قائمة اختبارات الجهة.

شهادات ISO: من الاختبار إلى اللقب المهني

اللقب عند PECB	الخبرة	ساعات المشاريع
Provisional Implementer	لا شيء	لا شيء
Implementer	سنتان، منها سنة في إدارة أمن المعلومات	200
Lead Implementer	5 سنوات، منها سنتان في إدارة أمن المعلومات	300
Senior Lead Implementer	10 سنوات، منها 7 في إدارة أمن المعلومات	1000

⚠ إن كتبت في سيرتك Lead Implementer، فتأكد أنك تستحق اللقب، لا أنك حضرت الدورة فقط.

ISACA (1 من 2): التدقيق والمخاطر

ISACA CISA
Certified Information Systems Auditor

لمن؟	تدقيق تقنية المعلومات: الخط الثالث.
ماذا تعلّم؟	عملية التدقيق، وحوكمة التقنية، وتشغيل الأنظمة وحمايتها.
الخبرة	5 سنوات، وإعفاء حتى 3.
متى؟	بعد خبرة تدقيق. تستطيع الاختبار مبكراً.

ISACA CRISC
Risk and Information Systems Control

لمن؟	مخاطر التقنية: الخط الثاني.
ماذا تعلّم؟	الحوكمة، وتقييم المخاطر، والاستجابة والتقارير، والتقنية.
الخبرة	3 سنوات في مجالين من 4، بلا إعفاء.
متى؟	بعد سنتين أو ثلاث في المخاطر.

في ISACA تستطيع الاختبار أولاً، ثم تقديم طلب الشهادة خلال 5 سنوات من النجاح حين تكتمل الخبرة.

ISACA (2 من 2): الإدارة والحوكمة

ISACA CISM
Certified Information Security Manager

لمن؟ من يتجه لإدارة برنامج الأمن.

ماذا تعلّم؟ من 3 نوفمبر 2026: الحوكمة 18%، والمخاطر 20%، والبرنامج 33%، والحوادث 29%.

الخبرة 5 سنوات في 3 مجالات من 4، وإعفاء حتى سنتين.

متى؟ حين تتجه للإدارة.

ISACA CGEIT
Governance of Enterprise IT

لمن؟ قيادات حوكمة التقنية.

ماذا تعلّم؟ حوكمة تقنية المعلومات على مستوى الجهة.

الخبرة 5 سنوات، بلا إعفاء.

متى؟ مرحلة متقدمة.

ISC2: الحوكمة والمخاطر، ثم القيادة

ISC2 CGRC
Governance, Risk and Compliance

لمن؟	محللو GRC ومديروه.
ماذا تعلّم؟	7 مجالات في GRC وإدارة مخاطر الأنظمة.
الخبرة	سنتان في مجال واحد من 7. بلا خبرة: Associate ومهلة 3 سنوات.
متى؟	بعد سنة أو سنتين في GRC.

ISC2 CISSP
Systems Security Professional

لمن؟	قيادة الأمن.
ماذا تعلّم؟	8 مجالات واسعة، منها الأمن وإدارة المخاطر بنسبة 16%.
الخبرة	5 سنوات في مجالين من 8. بلا خبرة: Associate ومهلة 6 سنوات.
متى؟	بعد سنوات. ليست شهادة GRC خالصة.

Associate of ISC2: تنجح قبل اكتمال الخبرة، ثم تُمنح الشهادة حين تكتمل خلال المهلة.

الخصوصية (1 من 2): شهادتا IAPP

IAPP CIPP/E

Information Privacy Professional/Europe

لمن؟ قانونيون ومختصو حماية بيانات مرتبطون بأوروبا.

ماذا تعلّم؟ قانون حماية البيانات في أوروبا.

الخبرة لا شرط مذكور.

متى؟ إن ارتبط عملك بأوروبا، أو أردت أساساً قانونياً.

IAPP CIPM

Certified Information Privacy Manager

لمن؟ من يدير برنامج الخصوصية في جهة.

ماذا تعلّم؟ بناء برنامج الخصوصية وتشغيله، غير مرتبطة بقانون دولة واحدة.

الخبرة لا شرط مذكور.

متى؟ مناسبة للعمل على الخصوصية عملياً.

الخصوصية (2 من 2): CDPSE، وكيف تختار

ISACA CDPSE

Data Privacy Solutions Engineer

لمن؟ الجانب التقني للخصوصية.

ماذا تعلّم؟ هندسة الخصوصية في الأنظمة ودورة حياة البيانات.

الخبرة 3 سنوات، بلا إعفاء.

متى؟ بعد خبرة في الخصوصية.

قبل أن تختار

- لـ CIPP ستة تركيزات إقليمية: آسيا، وأستراليا، وكندا، والصين، وأوروبا، والولايات المتحدة.
- لا توجد بينها شهادة خاصة بالنظام السعودي.
- في السعودية الأساس نظام حماية البيانات الشخصية ولوائحه. الشهادة الدولية تبني عليه ولا تغني عنه.

المقارنة: كم سنة خبرة تحتاج؟

0 بلا خبرة	2 سنتان	3 سنوات	5 سنوات
CC	CGRC	CRISC	CISA
Security+	ISO Implementer	CDPSE	CISM
IT Risk Fund.			CGEIT
GRCP			CISSP
CIPP/E · CIPM			ISO Lead
ISO Provisional			

الخبرة المطلوبة قبل منح الشهادة، مع الإعفاءات المتاحة. الرسوم والتجديد في الملحق: الشريحة 221.

كيف تختار: ابدأ من الوظيفة، لا من الشهادة

الوظيفة المستهدفة	مدخل	تخصص	بعد اكتمال الخبرة
محلل GRC وامتثال الخط الثاني	CC أو Security+	GRCP أو ISO 27001 LI	CRISC أو CGRC
مدقق تقنية معلومات الخط الثالث	CC أو IT Audit Fund.	ISO 27001 LA	CISA
الخصوصية وحماية البيانات مثل مسؤول حماية البيانات	CC	CIPM أو CIPP/E	CDPSE
قيادة الأمن والحوكمة هدف بعيد	أي مسار مما سبق	CISM أو CISSP	CGEIT

☆ شهادة واحدة لكل مرحلة. ما بين المراحل خبرة ومشاريع، لا شهادة إضافية.

لغة التدريب ولغة الاختبار

لغة التدريب ليست لغة الاختبار

- ✓ قد تجد دورة تُشرح بالعربية، والاختبار بالإنجليزية.
- ✓ تحقق من لغة الاختبار في صفحة الجهة المانحة قبل الحجز.
- ✓ بعض الجهات تمنح وقتاً إضافياً لمن يختبر بغير لغته الأم.

الاختبار	العربية؟
ISC2: CC وCISSP	لا عربية. CGRC: الإنجليزية فقط
ISACA: الشهادات الخمس	لا عربية. اللغات تختلف لكل شهادة
CompTIA Security+	لا عربية في الإصدار الحالي
IAPP: CIPP/E وCIPM	لا عربية
PECB وOCEG وIT Risk Fund.	لم نتحقق. راجع صفحة الجهة

القائمة الكاملة للغات كل اختبار في الملحق: الشريحتان 224 و225.

كيف تذاكر لأي شهادة: أربع خطوات

1

مخطط الاختبار

Exam Outline مجاني. المجالات وأوزانها خطتك.

←

2

مصدر أساسي واحد

الدليل الرسمي أو دورة معتمدة.

←

3

بنك أسئلة بفهم

لماذا الصحيح صحيح، والباقي خطأ.

←

4

احجز حين تثبت درجاتك

تتجاوز حد النجاح مرة بعد مرة.

فكّر كمدير: أسئلة ISACA وISC2 تسأل عن «الأفضل» أو «الأول» من منظور المخاطر.

طابق مادتك مع مخطط يوم اختبارك: CC وCISM وSecurity+ وCISSP تتغير بين 2026 و2027.

تمرين: اختر الشهادة المناسبة

سارة خريجة نظم معلومات، بلا خبرة، تريد وظيفة محللة امتثال خلال سنة.

عبدالله محاسب بخبرة 4 سنوات في المراجعة الداخلية، يريد التحول إلى تدقيق تقنية المعلومات.

نورة محامية بخبرة سنتين، مهتمة بحماية البيانات الشخصية.

الشخص	شهادة الآن	شهادة لاحقاً	السبب في جملتين
سارة			
عبدالله			
نورة			

اكتب في الكراسة. 8 دقائق.

الإجابة: اقتراحات للأشخاص الثلاثة

الشخص	الاقتراح	لماذا
سارة	CC أو Security+ الآن، ثم ISO 27001 Lead Implementer أو GRCP. CRISC أو CGRC لاحقاً بعد اكتمال الخبرة.	شهادة مدخل بلا شرط خبرة، ثم مهارة تطبيقية مطلوبة في الإعلانات.
عبدالله	ISO 27001 Lead Auditor أو IT Audit Fundamentals الآن، وCISA هدفاً قريباً.	خبرته في المراجعة قد تُحتسب لشرط CISA بحسب قواعد ISACA، فتحقق منها. Lead Auditor يبني على مهارة التدقيق لديه.
نورة	CIPP/E أو CIPM الآن، مع قراءة نظام حماية البيانات الشخصية ولوائحه.	خلفيتها القانونية تناسب CIPP/E، وCIPM يضيف إدارة برنامج الخصوصية. لا تحتاج شهادة تقنية أولاً.

اختبار قصير: الوحدة 05

3

أسئلة قصيرة

6 دقائق

ما يغطيه الاختبار:

- ✓ الشهادة المناسبة لمرحلتك.
- ✓ منفذ رئيسي أم مدقق رئيسي.
- ✓ لغة التدريب ولغة الاختبار.

أوقف الفيديو، وأجب في الكراسة في قسم «اختبار الوحدة 05». ثم قارن بالإجابات المفسرة، وانتبه لسبب خطأ كل بديل.

06 خطة البداية وملف الأعمال

الخبرة أكبر عائق للمبتدئ. هنا تحول تطبيقات الكورس إلى دليل على قدرتك قبل أول وظيفة.

بعد هذه الوحدة ستستطيع أن:

- تحول التطبيقات الأربعة إلى مشاريع منشورة.
- تبني خطة 90 يوماً واقعية.
- تكتب صفحة تعريفية لكل مشروع.

خطة 90 يوماً: من الصفر إلى أول طلب توظيف

على أساس 8 إلى 10 ساعات أسبوعياً تقريباً. عدّلها حسب وقتك.

الأساس — الأيام 1 إلى 30

- ✓ الوحدات 1 إلى 4 والتطبيقات الأربعة
- ✓ قراءة NIST CSF 2.0
- ✓ بدء مذاكرة شهادة مدخل

المخرَج: تطبيقات مصححة في الكراسة.

التطبيق — الأيام 31 إلى 60

- ✓ مشروعان من الشريحة التالية
- ✓ قراءة إطار قطاعك
- ✓ حجز اختبار الشهادة

المخرَج: مشروعان منشوران بصفحتين تعريفيتين.

السوق — الأيام 61 إلى 90

- ✓ السيرة ولينكدإن
- ✓ طلبات أسبوعية ومحادثات تعريفية
- ✓ خمس قصص STAR

المخرَج: طلبات مقدمة واستعداد للمقابلة.

من تطبيق صغير إلى مشروع في ملف أعمالك

ما نفذته في الكورس	المشروع الأكبر لملف أعمالك
1. مسؤوليات وبند سياسة	حزمة: سياسة ومعيار وإجراء لموضوع واحد
2. خطر واحد	سجل مخاطر من 10 مخاطر، ثم 20
3. تقييم ضابط	تقييم مكوّن فرعي كامل من ECC، مثل 2-2
4. ملاحظة وخطة تصحيح	تقرير تدقيق مصغر من 3 ملاحظات
مخاطر الأطراف الخارجية	استبيان تقييم مورد وتحليل ردوده
الأطر	مصفوفة مواءمة: ECC مقابل ISO 27001 وNIST CSF

⚠ رُفاد، أو جهة افتراضية مثلها، دائماً. لا تنشر وثائق أو بيانات من جهة حقيقية، حتى لو تدربت فيها.

صفحة تعريفية لكل مشروع

صفحة واحدة في بداية كل مشروع: يقرؤها مسؤول التوظيف في دقيقة.

عنوان المشروع سجل مخاطر مصغر لشركة لوجستية افتراضية

المشكلة	لا يوجد سجل مخاطر، والإدارة لا تعرف أين تبدأ.
ما فعلته	حددت 10 مخاطر، وقيمتها بمصفوفة NFCRM، واقترحت معالجة لكل خطر عالٍ.
النتيجة	3 مخاطر عالية بخطط ومالكين ومواعيد.
ما تعلمته	الضابط يغير الاحتمال أو الأثر، لا الاثنين دائماً.
الملفات	السجل، وصفحة المنهجية. بيانات افتراضية.

المهارات المطلوبة، وكيف تتدرب عليها

مهارات المجال

قراءة الأطر	الأسئلة الأربعة مع كل ضابط
تقييم المخاطر	التطبيق 2 ثم مشروع السجل
فحص الأدلة	التطبيق 3
أساسيات تقنية	الهويات والشبكات والسحابة
Excel	الجداول المحورية والتنسيق الشرطي

مهارات شخصية، وغالباً هي الفارق

الكتابة الواضحة	ملاحظة في 3 أسطر بدل 10
شرح التقني لغير التقني	خطر في دقيقة لصديق
الإقناع	اربط التوصية بأثر على العمل
المتابعة	مالك وموعد لكل شيء
النزاهة والسرية	لا مجاملة، ولا إفشاء

🌐 والإنجليزية: أغلب المعايير والاختبارات بها. اقرأ يومياً ولو صفحة.

تمرين: صفحة مشروع تقييم الصلاحيات

اكتب صفحة تعريفية لمشروعك من التطبيقين 3 و4: تقييم مراجعة الصلاحيات في رُفاد.

عنوان المشروع

المشكلة

ما فعلته

النتيجة

ما تعلمته

الملفات المرفقة

10 دقائق.

الإجابة: صفحة المشروع

عنوان المشروع	تقييم مراجعة الصلاحيات في نظام الرواتب، شركة افتراضية
المشكلة	معيار يطلب مراجعة ربع سنوية، ولا نعرف هل تُنفذ فعلاً.
ما فعلته	حللت 6 أدلة، وحددت نتيجة «مطبق جزئياً»، وكتبت ملاحظة وخطة تصحيح بأربعة إجراءات.
النتيجة	ملاحظة واحدة بمالكين ومواعيد وأدلة إغلاق، و4 أسئلة متابعة قبل الإغلاق.
ما تعلمته	وجود المعيار لا يثبت التشغيل، والسبب يحتاج تحققاً قبل كتابته.
الملفات المرفقة	ورقة التقييم، ونص الملاحظة، وخطة التصحيح. كلها ببيانات افتراضية.

اختبار قصير: الوحدة 06

3

أسئلة قصيرة

6 دقائق

ما يغطيه الاختبار:

- ✓ ما تنشره في ملف أعمالك وما لا تنشره.
- ✓ صفحة المشروع.
- ✓ الصدق في وصف المشروع التدريبي.

أوقف الفيديو، وأجب في الكراسة في قسم «اختبار الوحدة 06». ثم قارن بالإجابات المفسرة، وانتبه لسبب خطأ كل بديل.

07

السيرة الذاتية

سيرة تقرؤها الأنظمة والبشر، وتقول «أستطيع أن أفعل» لا «أنا مهتم».

بعد هذه الوحدة ستستطيع أن:

- تبني سيرة من صفحة واحدة بالترتيب المناسب للمبتدئ.
- تكتب إنجازات بالمعادلة: فعل، ثم ماذا، ثم كيف، ثم النتيجة.
- تتجنب الأخطاء الشائعة، وتصوغ خبرتك السابقة بلغة GRC.

تشريح سيرة مبتدئ (1 من 2): الرأس والملخص والمهارات

Sara Ahmed

Entry-Level GRC Analyst | Risk · Control Testing 1

Riyadh · sara.ahmed@email.com · linkedin.com/in/sara-ahmed-grc

SUMMARY 2

Entry-level GRC analyst with hands-on risk assessment and control testing projects. ISC2 CC.

SKILLS 3

Risk Assessment · Control Testing · ISO 27001 · NIST CSF · NCA ECC · Excel

نموذج تعليمي: الجزء الأعلى من سيرة من صفحة واحدة، والاسم والبيانات افتراضية.

1. العنوان: مسمى الوظيفة التي تستهدفها.
2. ملخص في سطرين: من أنت، وماذا تجيد.
3. المهارات بكلمات الإعلان نفسها، إن كانت صادقة عنك.

تشريح سيرة مبتدئ (2 من 2): المشاريع والتعليم والشهادات

PROJECTS 4

Vendor Access Risk · Fictional 200-staff company

• Rated a vendor remote-access risk High (16); proposed 5 actions with owners.

Access Review Assessment · Same company

• Tested 6 evidence items; wrote a finding with a 4-step corrective plan.

EDUCATION

B.Sc. Information Systems, 2025

CERTIFICATIONS 5

ISC2 CC, 2026

بقية الصفحة نفسها. نموذج تعليمي ببيانات افتراضية.

4 المشاريع قبل التعليم إن لم تكن لديك خبرة.

5 الشهادات باسمها والسنة. «قيد الدراسة» مع موعد مقبولة.

صفحة واحدة للمبتدئ. بلا صورة ولا عمر ولا حالة اجتماعية، إلا إن طلبها الإعلان.

أنظمة الفرز (ATS): البسيط أضمن

1 ترسل السيرة ← 2 يستخرج النظام النص ← 3 يقارن بالإعلان ← 4 يرتب أو يصفّي ← 5 يقرأ إنسان

يقلل احتمال الخطأ

- ✓ ملف نصي، لا صورة ممسوحة
- ✓ عناوين قياسية: Experience وSkills
- ✓ مصطلحات الإعلان إن كانت صادقة عنك
- ✓ عمود واحد ومعلومات الاتصال في المتن

قد يسبب مشكلة في بعض الأنظمة

- ⚠ نصوص داخل صور أو مربعات نص
- ⚠ جداول وأعمدة معقدة
- ⚠ أشرطة تقييم المهارات
- ⚠ حشو كلمات لا تعرفها

الأنظمة تختلف كثيراً، وبعضها يقرأ التنسيقات المعقدة جيداً. البسيط أضمن، لا أكثر.

صياغة الإنجاز: قبل وبعد

فعل قوي + ماذا فعلت + بأي طريقة + النتيجة أو الرقم

AFTER

Built a 5-activity RACI for leaver access revocation and wrote a policy clause with owner, deadline and evidence.

BEFORE

Responsible for the RACI matrix.

AFTER

Wrote and scored a payroll-laptop risk on the NCA 5×5 matrix (12, Medium) and planned encryption with a 30-day due date.

BEFORE

Did risk assessment.

الأرقام في سيرتك يجب أن تكون حقيقية: ستُسأل عن كل رقم.

بلا خبرة في GRC؟ خبرتك أقرب مما تظن

ترجم خلفيتك إلى لغة GRC

الدعم الفني	طلبات الصلاحيات، وسير الموافقات، والبلاغات
المحاسبة والتدقيق	الرقابة الداخلية، والأدلة، والعينات
القانون	الأنظمة واللوائح، والعقود، والخصوصية
إدارة الجودة	أنظمة الإدارة، والتدقيق الداخلي، والإجراءات
إدارة المشاريع	متابعة المعالجة بمالك وموعد، وتقارير الحالة

أقسام تملأ مكان الخبرة

- ✓ Projects: مشاريع الوحدة 5
- ✓ Internship: التدريب التعاوني
- ✓ Volunteering: سياسة لجمعية
- ✓ Capstone: مشروع التخرج

ستة أخطاء شائعة، وتصحيح كل منها

الخطأ	التصحيح
سيرة من ثلاث صفحات لمبتدئ	صفحة واحدة
«Responsible for...» في كل سطر	فعل، ثم ماذا، ثم كيف، ثم النتيجة
أخطاء إملائية في وظيفة تقوم على الدقة	مدقق إملائي، ثم قراءة شخص آخر
نسخة واحدة لكل الإعلانات	عدّل الملخص والمهارات للإعلان المهم
شهادة لم تحصل عليها	ما حصلت عليه، أو «قيد الدراسة» مع موعد
رقم الهوية أو الجواز في السيرة	الاسم والمدينة ووسائل التواصل تكفي

تمرين: أعد صياغة ثلاثة أسطر

أعد صياغة كل سطر بالمعادلة، مستخدماً ما نفذته في التطبيقات 2 و3 و1.

السطر الضعيف	صياغتك
Responsible for risk assessment.	
Helped with access review.	
Familiar with NCA ECC.	

بالإنجليزية، وبأرقام حقيقية من تطبيقاتك. 8 دقائق.

الإجابة: ثلاثة أسطر بعد إعادة الصياغة

قبل	بعد
Responsible for risk assessment.	Assessed a vendor remote-access risk for a fictional 200-staff company; rated it High (16) and proposed 5 actions with owners and dates.
Helped with access review.	Tested a quarterly access review against 6 evidence items; rated it partially implemented and wrote a finding with a 4-step corrective plan.
Familiar with NCA ECC.	Mapped ECC-2:2024 controls 2-2-3-2 and 2-2-3-5 to evidence requests and test steps for a training case.

كل سطر يبدأ بفعل، ويذكر الطريقة، وينتهي بنتيجة أو رقم من عملك الفعلي على حالة تدريبية.

اختبار قصير: الوحدة 07

3

أسئلة قصيرة

6 دقائق

ما يغطيه الاختبار:

- ✓ معادلة سطر الإنجاز.
- ✓ أنظمة الفرز ATS.
- ✓ المبالغة في الوصف.

أوقف الفيديو، وأجب في الكراسة في قسم «اختبار الوحدة 07». ثم قارن بالإجابات المفسرة، وانتبه لسبب خطأ كل بديل.

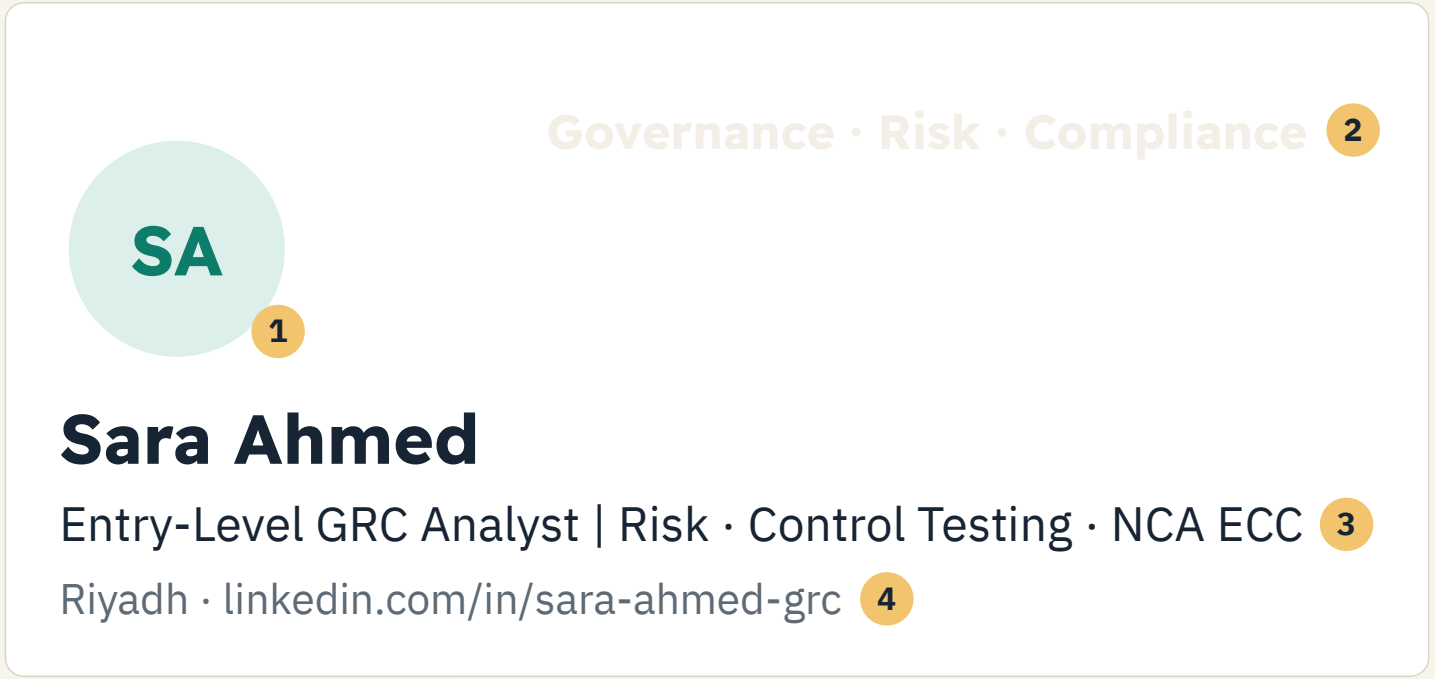
08 لينكدإن والفرص

ملفك يعمل وأنت نائم: يجده مسؤول التوظيف حين يبحث، ويقرؤه قبل أن يتصل بك.

بعد هذه الوحدة ستستطيع أن:

- تكمل ملفك: الصورة، والعنوان، والنبذة، وقسم Featured.
- تبني شبكة وتنشر بطريقة آمنة ومهنية.
- تستخدم Open to Work والبحث بأكثر من مسمى.

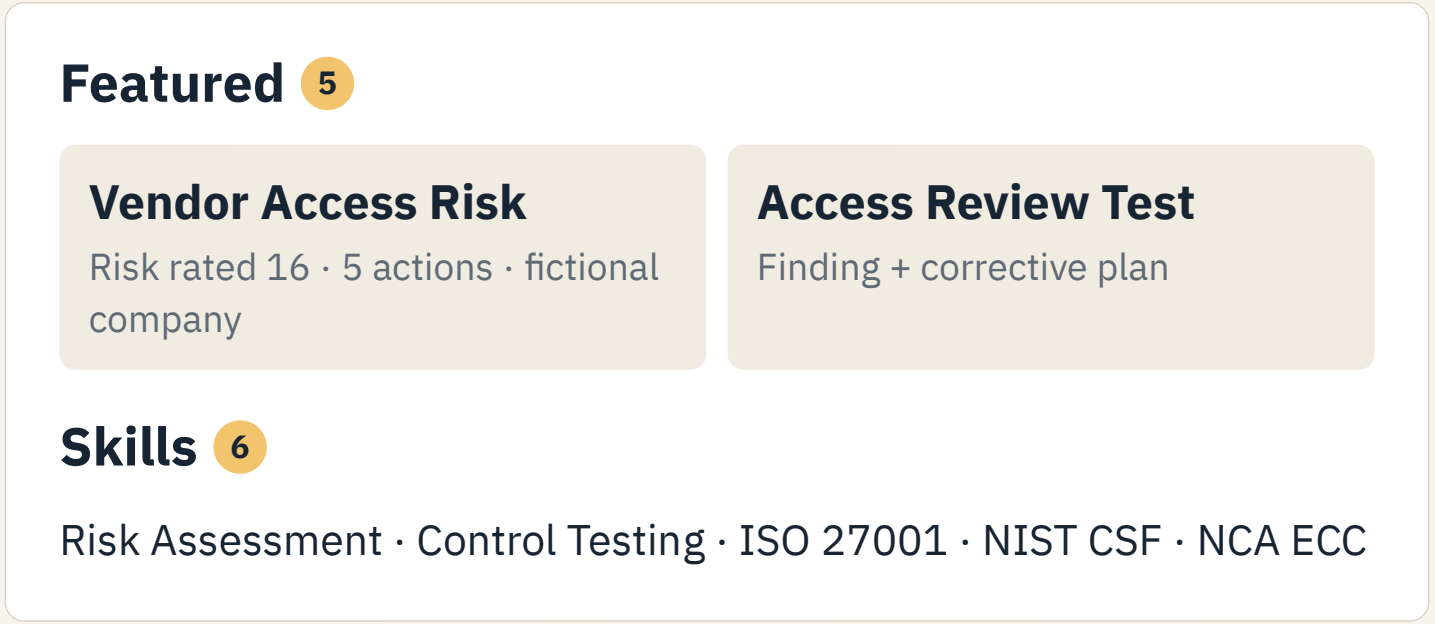
تشريح ملف لينكدإن (1 من 2): الرأس والعنوان



رسم توضيحي مبسط ببيانات افتراضية، ليس لقطة من لينكدإن.

1. الصورة: من 400×400 بكسل، حتى 8 ميغابايت، JPG أو PNG.
2. الخلفية: المقاس الموصى به 1584×396 بكسل.
3. العنوان المهني: الوظيفة المستهدفة وكلماتها.
4. رابط مخصص: من 3 إلى 100 حرف، بلا مسافات أو رموز.

تشريح ملف لينكدإن (2 من 2): المشاريع والمهارات



رسم توضيحي مبسط ببيانات افتراضية، ليس لقطة من لينكدإن.

5 Featured: مشاريعك أعلى الملف. لا يظهر إن كان فارغاً.

6 المهارات: حتى 100 مهارة. أهمها في الأعلى.

العنوان المهني: أهم سطر في ملفك

الوظيفة المستهدفة | **مجالان أو ثلاثة** | **دليل: شهادة أو مشروع**

قوي

Entry-Level GRC Analyst | Risk Assessment · ISO 27001 · NCA ECC | ISC2 CC

IT Support → GRC | Access Management · NIST CSF 2.0 | Security+

محلل حوكمة ومخاطر وامتثال | ECC · ISO 27001 | مشروعا تقييم

ضعيف

Computer Science Student

Looking for opportunities

Cybersecurity enthusiast | Hard worker

لم نجد حداً رسمياً لعدد الحروف في صفحات المساعدة. ضع أهم الكلمات في البداية.

نبذة About: أربعة أجزاء في فقرات قصيرة

About

Entry-level GRC analyst focused on turning requirements into clear, testable controls.

In a training case for a 200-staff company, I rated a vendor access risk and tested a quarterly access review, then wrote a finding with a corrective plan.

Focus: risk assessment · control testing · ISO/IEC 27001 · NIST CSF 2.0 · NCA ECC · ISC2 CC.

Open to entry-level GRC and compliance roles in Riyadh. See my projects in Featured.

1. الافتتاح
من أنت، وما تركيزك.

2. الدليل
مشروعان بنتائج محددة.

3. المجالات والأطر
كلمات البحث.

4. الدعوة
ماذا تبحث عنه، وكيف يتواصلون معك.

الحد 2,600 حرف، لكن 150 إلى 250 كلمة تكفي غالباً.

الشبكة والنشر: كن مرئياً في مجالك

من تضيف، وكيف

- مختصو GRC في الجهات التي تستهدفها
- مسؤولو التوظيف في الأمن السيبراني
- زملاء الدراسة والدورات والفعاليات

> «أ. نورة، استفدت من منشورك عن تقييم الموردين. أنا في بداية مساري في GRC، ويسعدني التواصل.»

ماذا تنشر

1. ضابط واحد بمثال من الواقع
2. مشروع من ملف أعمالك وما تعلمته
3. خلاصة فعالية حضرتها
4. تعليق مفيد على منشور مختص

⚠ لا تنشر أي تفصيل عن ضوابط أو ثغرات جهة عملت أو تدربت فيها.

البحث عن الفرص: Open to Work والمسميات

فعّل Open to Work

Me → View profile → Open to → Finding a new job

كل الأعضاء يراه الجميع، ويضيف إطار #OpenToWork.

مسؤولو التوظيف فقط لا تضمن LinkedIn إخفاءه تماماً عن جهتك الحالية.

ابحث بأكثر من مسمى

- **GRC Analyst**
- **Cybersecurity Compliance**
- **IT Risk Analyst**
- **IT Auditor**
- **Security Controls Assessor**
- **Cybersecurity Policy Officer**

وبالعربية: محلل حوكمة ومخاطر

- تنبيه وظائف لكل مسمى، وقدّم مبكراً.
- قدّم أيضاً من مواقع الجهات مباشرة.

تمرين: عنوانك وافتتاح نبذتك

العنوان المهني

الوظيفة | مجالان أو ثلاثة | دليل

افتتاح النبذة

جملتان: من أنت، وأقوى دليل من مشاريعك

بالإنجليزية، ومن مشاريعك الفعلية. 8 دقائق.

الإجابة: عنوان وافتتاح نموذجيان

العنوان

Entry-Level GRC Analyst | Risk Assessment · Control Testing · NCA ECC | ISC2 CC

الافتتاح

Entry-level GRC analyst who turns requirements into clear, testable controls. In a training case for a 200-staff company, I rated a vendor access risk, tested an access review, and wrote a finding with a corrective plan.

كلمات البحث في البداية، ودليل حقيقي، ولا مبالغة: «training case» تقول الحقيقة وتحميك في المقابلة.

اختبار قصير: الوحدة 08

3

أسئلة قصيرة

6 دقائق

ما يغطيه الاختبار:

- ✓ العنوان المهني.
- ✓ خيار Open to Work وحدوده.
- ✓ البحث بأكثر من مسمى.

أوقف الفيديو، وأجب في الكراسة في قسم «اختبار الوحدة 08». ثم قارن بالإجابات المفسرة، وانتبه لسبب خطأ كل بديل.

09

المقابلة والانطلاق

كل ما تعلمته يُختبر في ساعة واحدة. استعد لها كما تستعد لاختبار الشهادة.

بعد هذه الوحدة ستستطيع أن:

- تجيب عن الأسئلة المتوقعة بأمثلة من رُفاد.
- تحكي قصصك بطريقة STAR.
- تنطلق بخطة واضحة لما بعد الكورس.

ثمانية أسئلة متوقعة، وأين جوابها

«ما الفرق بين التهديد والثغرة والخطر؟»
يختبر: المفاهيم — 59

«مالك نظام يرفض تطبيق ضابط. ماذا تفعل؟»
يختبر: الإقناع والبدائل — 210

«كيف تقيّم خطراً وترتبه؟»
يختبر: المصفوفة والمبرر — 64

«ما الفرق بين الامتثال والمراجعة الداخلية؟»
يختبر: الخطوط الثلاثة — 39

«ما الفرق بين السياسة والمعيار والإجراء؟»
يختبر: هرم الوثائق — 40

«اشرح ECC أو ISO 27001 لمدير غير تقني»
يختبر: التبسيط — 150

«كيف تتأكد أن ضابطاً مطبق فعلاً؟»
يختبر: الأدلة والفترة — 91

«لماذا GRC؟ ولماذا جهتنا؟»
يختبر: دافعك وبحثك — جهّزه بنفسك

إجابة نموذجية: مالك نظام يرفض الضابط

السؤال: «مالك نظام يرفض تطبيق ضابط. ماذا تفعل؟» مثال من رُفاد: سلمان يرفض فرض التحقق على حساب المورد خوفاً من تعطل الدعم.

1. **افهم السبب:** «ما الذي يمنع التطبيق؟ تكلفة، أم تعطّل عمل، أم سوء فهم؟»
2. **اشرح الخطر بلغة العمل:** «حساب مشترك بلا تحقق قد يكشف بيانات 50 ألف مستلم.»
3. **اقترح بديلاً:** ضابط تعويضي، أو تطبيق مرحلي بموعد.
4. **إن تعذر: استثناء موثق:** مؤقت، بموافقة صاحب الصلاحية، ومراجعة دورية.
5. **التصعيد آخر خطوة:** للجنة، بالحقائق لا بالشكوى.

ما يقيسه السؤال: هل تعالج الخلاف بفهم المخاطر والعلاقة، لا بالمادة والنص فقط؟

طريقة STAR: قصة قصيرة بنتيجة واضحة

السؤال: «حدثنا عن مرة حللت فيها مشكلة معقدة.» مثال محلول من التطبيق 2.

S الموقف

في مشروع تدريبي، كان لمورد الدعم حساب إداري مشترك على أداة مكشوفة.

T المهمة

تقييم الخطر واقتراح معالجة.

A ما فعلته أنا

كتبت الخطر، وقيمته بمصفوفة الهيئة مع مبرر كل درجة، واقترحت 5 إجراءات بمالكين ومواعيد.

R النتيجة

خطر عالٍ (16) بخطة تنزله إلى متوسط، وقرار مطلوب من الإدارة للباقي.

دقيقة إلى دقيقتين

«أنا» في الإجراء، لا «نحن»

جهّز 5 قصص مسبقاً

تمرين: قصتك بطريقة STAR

السؤال: «حدثنا عن مرة اكتشفت فيها مشكلة في ضابط ولم يكن الدليل واضحاً.»

S الموقف

T المهمة

A ما فعلته أنا

R النتيجة

استخدم التطبيقين 3 و4. 8 دقائق.

الإجابة: قصة STAR نموذجية

S	**الموقف**	في مشروع تدريبي لشركة افتراضية، كان المطلوب تقييم مراجعة الصلاحيات الفصلية في نظام الرواتب.
T	**المهمة**	تحديد نتيجة التقييم من 6 أدلة متفاوتة.
A	**ما فعلته أنا**	ربطت كل دليل بما يثبته، فوجدت أن الربع الثاني لم يُنفذ وأن حسابين لمغادرين بقيا نشطين، ثم طلبت سجل الترحيل للتحقق من السبب بدل الاعتماد على البريد.
R	**النتيجة**	قيّمت الضابط «مطبقاً جزئياً» وكتبت ملاحظة بخطة تصحيح من 4 إجراءات، ونشرت المشروع في ملف أعمالي.

اختبار قصير: الوحدة 09

3

أسئلة قصيرة

6 دقائق

ما يغطيه الاختبار:

- ✓ قصة STAR.
- ✓ التعامل مع مالك نظام يرفض ضابطاً.
- ✓ الحديث عن مشروع تدريبي.

أوقف الفيديو، وأجب في الكراسة في قسم «اختبار الوحدة 09». ثم قارن بالإجابات المفسرة، وانتبه لسبب خطأ كل بديل.

التقييم الختامي: النسخ الاحتياطي للرواتب

نظام الرواتب خدمة سحابية SaaS. المزود ينسخ البيانات، ورُفاد تصدّر نسخة إضافية بنفسها. تبنّت رُفاد طوعاً متطلبات ECC 2-9-3: نطاق النسخ، والاستعادة السريعة، والفحص الدوري لفعالية الاستعادة. الفترة: 1 يناير إلى 30 يونيو 2026.

الأدلة الأربعة كاملة في الكراسة:

د1 تحليل أثر الأعمال	د2 وصف خدمة المزود	د3 تقرير التصدير	د4 لا اختبار استعادة

المطلوب: ساعة واحدة

1. حدّد الخطر: اكتبه بصيغة بسبب... قد... مما يؤدي إلى...، وقيّمه بالمصفوفة مع مبرر لكل درجة.
2. اختر ضابطين على الأقل يعالجان الخطر، ولكل منهما مالك.
3. قيّم الأدلة الأربعة: ماذا يثبت كل منها وماذا لا يثبت؟ وما نوع كل فجوة: تصميم، أم تنفيذ، أم تشغيل؟
4. اكتب ملاحظة بعناصرها الخمسة، وخطة تصحيح من 4 إجراءات بمالك وموعد ودليل إغلاق.

قائمة المراجعة: هل أنت جاهز للتقديم؟

المعرفة

- ☐ أشرح مصطلحات المخاطر بمثال
- ☐ أفرق بين السياسة والمعيار والإجراء
- ☐ أعرف ما ينطبق على قطاعي

التطبيق

- ☐ أنهيت التطبيقات الأربعة وصححتها
- ☐ مشروعان منشوران بصفحتين
- ☐ لا بيانات لجهة حقيقية

الشهادة

- ☐ اخترت شهادة مدخل واحدة
- ☐ قرأت مخطط اختبارها الحالي
- ☐ تحققت من الرسوم واللغة

السوق

- ☐ سيرة صفحة واحدة بإنجازات
- ☐ ملف لينكدإن مكتمل
- ☐ 5 قصص STAR جاهزة

نهاية الكورس، وبداية المسار

ابدأ هذا الأسبوع بثلاث خطوات

لا تنتظر أن تكتمل الصورة. خطوة كل أسبوع، ودليل تراه أنت وغيرك.

الأسعار والشروط والإصدارات كما في 27 أكتوبر 2026. تحقق منها قبل التسجيل.

1 **اختر شهادة المدخل**
واقرأ مخطط اختبارها الرسمي

2 **وسّع التطبيق 2**
إلى سجل من 10 مخاطر

3 **حدّث عنوانك في لينكدإن**
بالمعادلة من الشريحة 201

الملحق المرجعي

جداول وأرقام تتغير، فصلناها عن الدروس لتحدّثها بسهولة: القاموس، ورسوم الشهادات، وصيغ الاختبارات ولغاتها، والمراجع السعودية، والروابط.

الملحق المرجعي مرجع قابل للتحديث

القاموس (1 من 2)

سجل المخاطر Risk Register
قائمة المخاطر بالمالك والدرجة والمعالجة

شهية المخاطر Risk Appetite
حجم الخطر الذي تقبله الجهة عموماً

حدود التحمل Risk Tolerance
حدود قابلة للقياس لخطر أو مؤشر

الخطر المتأصل Inherent Risk
قبل تنفيذ خطط المعالجة

الخطر المتبقي Residual Risk
بعد احتساب خطط المعالجة

مؤشر المخاطر الرئيسي KRI
رقم ينبه مبكراً إلى ارتفاع خطر

تقييم الفجوات Gap Assessment
مقارنة الوضع القائم بمتطلبات مرجع

بيان قابلية التطبيق SoA
ضوابط ISO 27001 المطبقة والمستبعدة ولماذا

مالك الضابط Control Owner
من يطبق الضابط ويحتفظ بأدلته

القاموس (2 من 2)

ضابط تعويضي Compensating Control
بديل يحقق الهدف حين يتعذر الأصلي

استثناء Policy Exception
إعفاء داخلي موثق ومؤقت من متطلب

فصل المهام SoD
لا ينفذ شخص واحد العملية ويعتمدها

أقل صلاحية Least Privilege
صلاحيات بقدر حاجة العمل فقط

العناية الواجبة Due Diligence
التحقق من المورد قبل التعاقد

المجتمع والعينة Population / Sample
كل الحالات، وجزء مختار منها

الملاحظة Finding
فجوة بين الوضع القائم والمعيار

خطة التصحيح Corrective Action Plan
إجراء ومالك وموعد ودليل إغلاق

تحليل أثر الأعمال BIA
أهم الخدمات وكم تتحمل الجهة توقفها

الملحق المرجعي · مرجع قابل للتحديث

رسوم الشهادات وتجديدها (1 من 2)

الشهادة	رسم الاختبار (دولار)	المحافظة والتجديد (دولار)
CC · ISC2	199	50 سنوياً، و45 ساعة CPE كل 3 سنوات
CGRC · ISC2	599	135 سنوياً، و60 ساعة CPE كل 3 سنوات
CISSP · ISC2	749	135 سنوياً، و120 ساعة CPE كل 3 سنوات
CISA · CISM · CRISC · CGEIT · CDPSE	575 للأعضاء، 760 لغيرهم، و50 للطلب	45 أو 85 سنوياً، و120 ساعة CPE كل 3 سنوات
IT Risk / Audit Fundamentals · ISACA	175 للأعضاء، 225 لغيرهم	لم تذكره الصفحة
Security+ · CompTIA	لم نتحقق: يُعرض حسب الدولة	50 وحدة CEU و150 كل 3 سنوات

تاريخ التحقق: 27 أكتوبر 2026. راجع الصفحة الرسمية قبل الدفع أو التسجيل. المصادر في الملاحظات.

الملحق المرجعي مرجع قابل للتحديث

رسوم الشهادات وتجديدها (2 من 2)

الشهادة	رسم الاختبار (دولار)	المحافظة والتجديد
CIPP/E · CIPM · IAPP	550 للأعضاء وغيرهم	250 كل سنتين و20 ساعة CPE، أو عضوية 295 سنوياً
GRCP · OCEG	ضمن اشتراك 499 أول سنة، ثم 399	مع الاشتراك. الصفحة تذكر قاعدتين متعارضتين
ISO 27001 LI/LA · PECB	حسب مقدم التدريب. بلا تدريب: 1,000 للاختبار و500 للطلب	كل 3 سنوات بساعات CPD ورسم سنوي لم نتحقق من قيمته

⚠ سعر إعادة اختبار IAPP كان 375 دولاراً في دليل 2022، ولم نتحقق من السعر الحالي.

تاريخ التحقق: 27 أكتوبر 2026. راجع الصفحة الرسمية قبل الدفع أو التسجيل.

الملحق المرجعي مرجع قابل للتحديث

صيغ الاختبارات: الأسئلة والمدة والنجاح

الشهادة	الأسئلة والمدة	النجاح
CC	100 إلى 125 · ساعتان · تكيفي	700 من 1000
CGRC	125 · 3 ساعات	700 من 1000
CISSP	100 إلى 150 · 3 ساعات · تكيفي	700 من 1000
Security+	حتى 90 · 90 دقيقة	750 من 900
IT Risk Fund.	غير مذكور · ساعتان	65%
GRCP	100 محتسبة · 120 دقيقة	70 سؤالاً

الشهادة	الأسئلة والمدة	النجاح
CISA · CISM	150 · 4 ساعات	450 من 800
CRISC · CGEIT	150 · 4 ساعات	450 من 800
CDPSE	120 · 3.5 ساعة	450 من 800
CIPP/E · CIPM	90 · ساعتان ونصف	300 من 500
PECB ISO 27001	80 · كتاب مفتوح	70%

تاريخ التحقق: 27 أكتوبر 2026. راجع الصفحة الرسمية قبل الدفع أو التسجيل.

الملحق المرجعي · مرجع قابل للتحديث

لغات الاختبارات (1 من 2): ISC2 وCompTIA وIAPP

الاختبار	لغات الاختبار
CC	الإنجليزية، الصينية، اليابانية، الألمانية، الإسبانية
CISSP	الإنجليزية، الصينية، الألمانية، اليابانية، الإسبانية
CGRC	الإنجليزية فقط
Security+ SY0-701	الإنجليزية، اليابانية، البرتغالية، الإسبانية، التايلندية
CIPP/E	الإنجليزية، الفرنسية، الألمانية
CIPM	الإنجليزية، الفرنسية، الألمانية، البرتغالية البرازيلية، الصينية المبسطة

لغة الاختبار تختلف عن لغة التدريب. تاريخ التحقق: 27 أكتوبر 2026. راجع الصفحة الرسمية قبل الدفع أو التسجيل.

الملحق المرجعي مرجع قابل للتحديث

لغات الاختبارات (2 من 2): ISACA وغيرها

الاختبار	لغات الاختبار
CISA	الإنجليزية، الإسبانية، الصينية المبسطة، الفرنسية، الألمانية، الكورية، اليابانية
CISM	الإنجليزية، الإسبانية، الصينية المبسطة، اليابانية، الفرنسية، الألمانية
CRISC	الإنجليزية، الإسبانية، اليابانية
CGEIT	الإنجليزية، الصينية المبسطة
CDPSE	الإنجليزية فقط
GRCP · IT Risk Fund. · PECB	غير مذكورة في الصفحات التي راجعناها

لم نجد العربية في أي من الاختبارات التي تحققنا منها. تاريخ التحقق: 27 أكتوبر 2026. راجع الصفحة الرسمية قبل الدفع أو التسجيل.

الملحق المرجعي · مرجع قابل للتحديث

المراجع السعودية (1 من 2): ضوابط الهيئة وإطار المخاطر

المرجع والإصدار	الجهة	النطاق المختصر
ECC-2:2024	الهيئة الوطنية للأمن السيبراني	الجهات الحكومية والتابعة، والبنية التحتية الوطنية الحساسة
NFCRM-1:2025	الهيئة الوطنية للأمن السيبراني	نطاق ECC نفسه
CCC-2:2024 · DCC-1:2022 · CSCC-1:2019	الهيئة الوطنية للأمن السيبراني	امتداد لـ ECC في سياقات محددة
OTCC-1:2022 · TCC-1:2021 · OSMACC-1:2021	الهيئة الوطنية للأمن السيبراني	امتداد لـ ECC في سياقات محددة

تاريخ التحقق: 27 أكتوبر 2026. راجع الصفحة الرسمية قبل الدفع أو التسجيل.

الملحق المرجعي مرجع قابل للتحديث

المراجع السعودية (2 من 2): الكوادر وساما وحماية البيانات

المرجع والإصدار	الجهة	النطاق المختصر
SCyWF-1.5:2026	الهيئة الوطنية للأمن السيبراني	الأدوار الوظيفية ومهامها
SAMA CSF 1.0 (2017)	البنك المركزي السعودي	الجهات الخاضعة لإشرافه
نظام حماية البيانات الشخصية	سدايا	نافذ منذ 14 سبتمبر 2023

تاريخ التحقق: 27 أكتوبر 2026. راجع الصفحة الرسمية قبل الدفع أو التسجيل.

الملحق المرجعي مرجع قابل للتحديث

روابط: الأطر والمراجع

الهيئة الوطنية للأمن السيبراني	nca.gov.sa
الإطار الوطني لإدارة المخاطر NFCRM	صفحة الإطار
الضوابط الأساسية ECC	صفحة الضوابط
الإطار السعودي لكوادر الأمن السيبراني	صفحة إطار الكوادر
إطار ساما للأمن السيبراني	rulebook.sama.gov.sa
NIST CSF 2.0	nist.gov/cyberframework
دليل NIST لاستخدام Tiers	SP 1302
ISO/IEC 27001	iso.org

الملحق المرجعي مرجع قابل للتحديث

روابط: الشهادات

ISC2: الشهادات	isc2.org/certifications
ISC2: أسعار الاختبارات	صفحة الأسعار
ISACA: الشهادات	isaca.org/credentialing
ISACA: تحديث مخطط CISM	البيان الصحفي
CompTIA Security+	comptia.org
IAPP	iapp.org/certify
OCEG GRCP	oceg.org
PECB	pecb.com

الملحق المرجعي مرجع قابل للتحديث

روابط: الخصوصية والقطاعات ولينكدإن

دليل سدايا لنظام حماية البيانات الشخصية	dgp.sdaia.gov.sa
PCI DSS: مكتبة الوثائق	pcisecuritystandards.org
COBIT	isaca.org/resources/cobit
LinkedIn: Open to Work	صفحة المساعدة
LinkedIn: الرابط المخصص	صفحة المساعدة
LinkedIn: المهارات	صفحة المساعدة

الملحق المرجعي مرجع قابل للتحديث

ما يحتاج تحديثاً دورياً

المعلومة	متى تراجعها	الشرائح
رسوم الشهادات وتجديدها	كل 6 أشهر	الشريحتان 221 و222
مخططات الاختبارات ولغاتها	كل 6 أشهر، وقبل كل تسجيل	169 و176 و223 إلى 225
إصدارات الضوابط والأطر السعودية	كل 6 أشهر	150 و151 و226 و227
الإطار الوطني لإدارة المخاطر	عند أي تحديث من الهيئة	61 إلى 64
إصدارات ISO وNIST وPCI DSS	سنوياً	142 إلى 149
حدود لينكدإن ومساراته	سنوياً	199 و204
نظام حماية البيانات وجهة الإشراف	كل 6 أشهر	87